



Mastère 2 Cybersécurité

Projet de groupe

Cyber Trust

RENDU DE GROUPE

SOC externalisé pour un réseau d'audioprothésistes

Client fictif : Daylight | Prestataire : Cyber Trust

Élément	Information
Établissement	Sup de Vinci : Mastère 2 Cybersécurité
Type de rendu	Rendu de groupe
Équipe projet	Kilyan FELIX · Yvan FOCSA · Youssef GUERNIOU · Mahamadou DIACOUMBA
Client	Daylight : réseau de centres d'audioprothésistes
Prestataire	Cyber Trust : SOC externalisé et infogérance sécurité

Sommaire

1. Présentation de l'entreprise et de l'équipe projet.....	3
2. Analyse de la problématique et introduction à la solution proposée.....	3
2.1. Périmètre démontré et périmètre cible.....	4
2.2. Surfaces d'attaque et hypothèses de compromission.....	4
3. Gestion des coûts.....	5
4. Organisation de l'équipe, planification détaillée et méthodologies appliquées.....	6
4.1. RACI synthétique.....	7
5. Présentation de la solution technique.....	7
5.1. Architecture globale et segmentation.....	7
5.2. Pare-feu pfSense, flux et journalisation SOC.....	8
5.2.1. Chaîne de preuves pfSense présentée au client.....	11
Preuve A : pfSense opérationnel et interfaces actives.....	12
Preuve B : Affectation WAN/LAN maîtrisée.....	12
Preuve C : Objets réseau lisibles et maintenables.....	13
Preuve D : Posture WAN restrictive.....	13
Preuve E : Blocages journalisés côté firewall.....	14
5.3. Plateforme SIEM Wazuh et collecte multi-source.....	15
5.4. Détection, qualification et scénarios de preuve.....	17
5.5. Exploitation SOC, playbooks et retour d'expérience.....	19
5.5.1. Chaîne opérationnelle proposée pour Daylight.....	20
5.5.2. Playbooks de réponse aux incidents.....	20
5.5.3. Qualification des alertes et niveaux de décision.....	20
5.5.4. Procédures d'exploitation du démonstrateur.....	21
5.5.5. Retours d'expérience et amélioration continue.....	21
5.5.6. Valeur apportée au client.....	22
5.6. Synthèse technique et conformité au cahier des charges.....	22
6. Conclusion.....	22
6.1. Guide d'utilisation synthétique.....	23
Annexes.....	23
Annexe A : Liste des preuves intégrées au rapport.....	23
Annexe B : Ports et flux principaux.....	24
Annexe C : Recommandations d'industrialisation.....	24
Annexe D : Schémas détaillés de la contribution architecture.....	25
Schéma pfSense, flux autorisés et flux bloqués.....	25
Schéma SOC Wazuh et chaîne de supervision.....	26
Ressources associées dans le dépôt.....	26
Annexe E : Compléments SIEM Youssef.....	28

1. Présentation de l'entreprise et de l'équipe projet

Daylight est un réseau fictif d'audioprothésistes réparti sur une trentaine de points de vente en France. Son activité implique la manipulation de données sensibles : informations patients, historiques de rendez-vous, dossiers de suivi, données administratives et accès aux applications métier. Le client ne dispose pas d'une équipe cybersécurité interne suffisamment dimensionnée pour assurer une surveillance continue, qualifier les alertes et maintenir une capacité de réponse homogène sur l'ensemble de ses sites.

Dans ce contexte, Cyber Trust intervient comme prestataire externe chargé de concevoir un démonstrateur de SOC externalisé. Le projet ne consiste pas seulement à installer un outil SIEM : il vise à proposer une organisation exploitable, des flux de collecte réalistes, des règles de détection compréhensibles, des tableaux de bord utiles et une trajectoire d'industrialisation vers les centres Daylight.

Lecture du besoin Daylight

Le besoin n'est pas uniforme sur tout le SI. L'équipe a donc raisonné par familles de sources, avec une logique simple : observer ce qui expose le plus le client et ce qui aide vraiment le SOC à qualifier un incident.

Les postes utilisateurs sont suivis pour les authentifications locales, les exécutions suspectes, l'usage USB et l'hygiène endpoint.

Les routeurs et firewalls apportent le contexte réseau : flux refusés, tentatives entrantes, changements de configuration et mouvements entre zones.

Les applications métier sont prioritaires car elles portent les dossiers patients, les rendez-vous et les actions sensibles.

Les serveurs internes donnent la visibilité sur l'AD, les fichiers, les bases et les élévations de privilèges. La messagerie reste un axe d'industrialisation important pour traiter le phishing et les pièces jointes malveillantes.

Membre	Rôle projet	Responsabilités défendues dans le rapport
Kilyan FELIX	Chef de projet / pilotage et qualification	Cadrage, planning, suivi des livrables, gestion des coûts, organisation de la soutenance et qualification des alertes côté client.
Yvan FOCSA	Architecte de la solution	Architecture cible, segmentation, pfSense, zones réseau, flux, posture WAN, journalisation firewall et trajectoire production.
Youssef GUERNIOU	Ingénieur SIEM Wazuh	Déploiement Wazuh, collecte multi-source, agents, règles, dashboards, RBAC et preuves de supervision.
Mahamadou DIACOUMBA	Exploitation SOC / procédures	Playbooks, procédures d'exploitation, scénarios de réponse, REX incident et maintien opérationnel du lab.

2. Analyse de la problématique et introduction à la solution proposée

La problématique de Daylight est double. D'une part, le réseau de centres doit protéger des données sensibles et maintenir une continuité de service sur ses applications métier. D'autre part, il doit le faire sans transformer chaque point de vente en mini-équipe sécurité. Le modèle pertinent est donc une supervision centralisée, opérée par un SOC externalisé, capable d'absorber des événements venant de plusieurs sites et de fournir des alertes qualifiées.

Le risque principal n'est pas limité à une attaque spectaculaire. Dans un réseau de santé de proximité, les incidents probables sont souvent plus simples : poste compromis, clé USB utilisée sans contrôle, tentative de force brute, accès anormal à un dossier patient, erreur de configuration firewall, mouvement latéral depuis un poste utilisateur vers un serveur interne, ou compte à privilèges modifié sans justification.

La solution proposée par Cyber Trust repose sur trois piliers : une architecture segmentée et défendable, une collecte SIEM centralisée avec Wazuh, et des procédures de traitement permettant de passer de l'alerte brute à une décision exploitable. Le démonstrateur prouve ces trois dimensions dans un environnement local volontairement maîtrisé.

Réponse retenue

Nous avons évité de présenter le projet comme une simple installation Wazuh. Le MVP combine une architecture segmentée, une collecte SIEM, des règles de détection et des procédures SOC. Ce choix rend la démonstration plus crédible pour Daylight : on ne montre pas seulement des alertes, on montre ce que Cyber Trust peut en faire.

Collecte multi-source : endpoint, serveur Linux, logs applicatifs Daylight et événements pfSense.

SIEM open-source : Wazuh centralise les événements et permet la restitution analyste/client.

Alerting personnalisable : règles natives pour SSH et règles dédiées pour Daylight et pfSense.

Exploitation : dashboards, RBAC, playbooks, REX et guide de reprise du lab.

Limite assumée : le lab prouve la faisabilité, mais la haute disponibilité et la rétention restent à dimensionner en production.

2.1. Périmètre démontré et périmètre cible

Point d'arbitrage : nous avons volontairement séparé le lab de la cible. Le lab doit rester stable pour la démonstration ; la cible sert à montrer comment Daylight pourrait industrialiser le service sans prétendre que tout est déjà déployé en production.

La différence entre le lab et la cible de production est assumée. Dans le lab, pfSense est déployé en VM, Wazuh fonctionne en single-node Docker et certaines briques Daylight sont simulées par des logs. En cible, ces éléments seraient répartis sur les sites et intégrés dans un modèle d'infogérance avec haute disponibilité, sauvegardes, rétention adaptée, supervision de composants et procédures de changement.

Élément	Démonstrateur	Cible industrialisable
pfSense	VM unique, WAN/LAN, règles et syslog démontrés	Pare-feu par site ou cluster, segmentation VLAN complète, VPN d'administration
Wazuh	Single-node Docker : Manager, Indexer, Dashboard	Architecture dimensionnée, rétention adaptée, sauvegardes, supervision de santé
Logs applicatifs	Logs Daylight simulés et injectés	Connecteurs applicatifs, normalisation, traçabilité par site
Sites Daylight	Sites représentés dans les dashboards et scénarios	Déploiement progressif sur les 30 centres avec template d'onboarding

2.2. Surfaces d'attaque et hypothèses de compromission

L'analyse de la problématique ne se limite pas au choix d'un SIEM. Pour un réseau d'audioprothésistes, les scénarios les plus réalistes concernent les postes de travail, les accès aux dossiers patients, les équipements réseau et les comptes d'administration. Le démonstrateur a donc été conçu pour prouver une chaîne complète : exposition, collecte, détection, qualification et réponse.

Menaces retenues pour le MVP

Pour rester défendable, le démonstrateur se concentre sur des scénarios probables dans un réseau de centres de santé de proximité. Nous avons privilégié les signaux faciles à expliquer au client et utiles pour déclencher une action SOC.

Poste compromis : authentifications anormales, exécution suspecte ou usage USB non maîtrisé.

Accès patient hors contexte : consultation inhabituelle, volume anormal ou compte non habilité.

Serveur interne visé : brute force SSH, accès partage sensible ou élévation de privilèges.

Segmentation contournée : tentative USERS vers MGMT, SERVERS ou SOC, bloquée puis journalisée par pfSense.

Plateforme SOC : séparation des rôles pour éviter qu'un profil de supervision modifie la configuration.

Cette lecture par surface d'attaque permet de justifier les choix d'architecture. Les composants réellement démontrés dans le lab sont associés à des preuves visibles, tandis que les briques plus larges, comme la messagerie ou l'automatisation avancée, sont traitées comme trajectoire d'industrialisation. Le rapport reste ainsi honnête sur le périmètre livré tout en montrant comment la solution peut évoluer vers une infogérance SOC complète.

3. Gestion des coûts

Le chiffrage est repris selon la logique proposée par Kilyan FELIX : distinguer l'investissement initial, le coût annuel d'exploitation et le coût marginal d'onboarding d'un nouveau centre. Cette présentation est plus lisible pour Daylight, car elle sépare ce qui relève du lancement du service de ce qui relève du run SOC.

L'hypothèse structurante est l'absence de coût de licence SIEM : Wazuh reste open-source. Les fourchettes ci-dessous restent indicatives, mais elles donnent un ordre de grandeur exploitable pour un pilote multi-sites.

Coûts de mise en place	Hypothèse	Min (€)	Max (€)
Licence SIEM Wazuh	Open-source	0	0
Serveur / VM SOC central	Cloud ou on-premise	1 500	3 000
Déploiement et configuration plateforme	Environ 5 j/h	2 500	4 000
Déploiement agents + collecte pilotes	Environ 3 j/h	1 500	2 500
Total mise en place	Investissement initial	5 500	9 500

Coûts récurrents annuels	Hypothèse	Min (€/an)	Max (€/an)
Hébergement infra SOC	VM / cloud	1 800	3 600
Stockage et rétention des logs	Volume 30 sites	1 200	3 000
Connectivité VPN site vers SOC	30 sites	1 000	2 000
Run SOC : supervision + analyse N1/N2	Poste principal	25 000	45 000
Maintenance / MAJ / support	Run et amélioration continue	3 000	6 000
Total récurrent annuel	Socle de service externalisé	32 000	59 600

Synthèse financière	Min	Max
Investissement initial one-shot	5 500 €	9 500 €
Coût de fonctionnement annuel	32 000 €	59 600 €
Nombre de points de vente	30	30
Coût annuel mutualisé par site	1 067 €	1 987 €
Coût marginal d'un nouveau centre	150 €	300 €

Lecture client : le modèle devient intéressant si l'exploitation est mutualisée. Le coût marginal d'un nouveau centre reste limité lorsque les agents, règles et dashboards sont déjà préparés ; l'enjeu principal est donc la standardisation de l'onboarding et la qualité de la supervision.

Passage à l'échelle

La montée en charge doit se faire progressivement. Le bon ordre est de valider quelques centres pilotes, stabiliser les sources, puis généraliser les templates. C'est ce qui évite de multiplier les faux positifs ou les configurations locales non maintenables.

Pilote 1 à 3 centres : validation des sources, des règles et du circuit d'escalade.

Déploiement 30 centres : onboarding par template pour garder une configuration homogène.

Exploitation continue : ajustement mensuel des règles, revue des faux positifs et reporting client.

4. Organisation de l'équipe, planification détaillée et méthodologies appliquées

L'équipe a appliqué une méthode simple : chaque tâche devait produire trois éléments vérifiables, à savoir une configuration technique, une preuve de fonctionnement et une explication exploitable dans le rapport ou la vidéo. Cette approche évite les livrables déclaratifs et oblige à lier chaque choix à une capture, une matrice, une règle, un dashboard ou une procédure.

Phase	Objectif	Responsable principal	Livrable de sortie
1. Cadrage	Comprendre Daylight, les briques SI et les exigences du cahier des charges	Kilyan	Périmètre, planning, répartition des rôles
2. Architecture	Définir les zones, flux, filtrage et intégration SOC	Yvan	Schémas, matrice zones/flux, configuration pfSense
3. SIEM	Déployer Wazuh et raccorder les sources obligatoires	Youssef	Manager/Indexer/ Dashboard, agents, syslog, dashboards
4. Détection	Créer et valider les scénarios clés	Youssef + Mahamadou	Règles, alertes, preuves de déclenchement
5. Réponse	Formaliser les actions de traitement	Mahamadou	Playbooks, procédures, REX incidents
6. Recette	Vérifier la démonstration de bout en bout	Équipe	Tests, captures, script vidéo

Le projet a également été piloté avec une logique de dépendances. L'architecture devait précéder les dashboards, car les noms de zones et de sources structurent la lecture des alertes. Le SIEM devait être opérationnel avant la qualification, car une alerte non indexée ne peut pas être défendue. Les playbooks ont été construits après les scénarios de détection afin de rester alignés sur les événements réellement observés.

Méthodologie appliquée

Planification du projet : SOC externalisé Daylight (janvier à juin 2026)

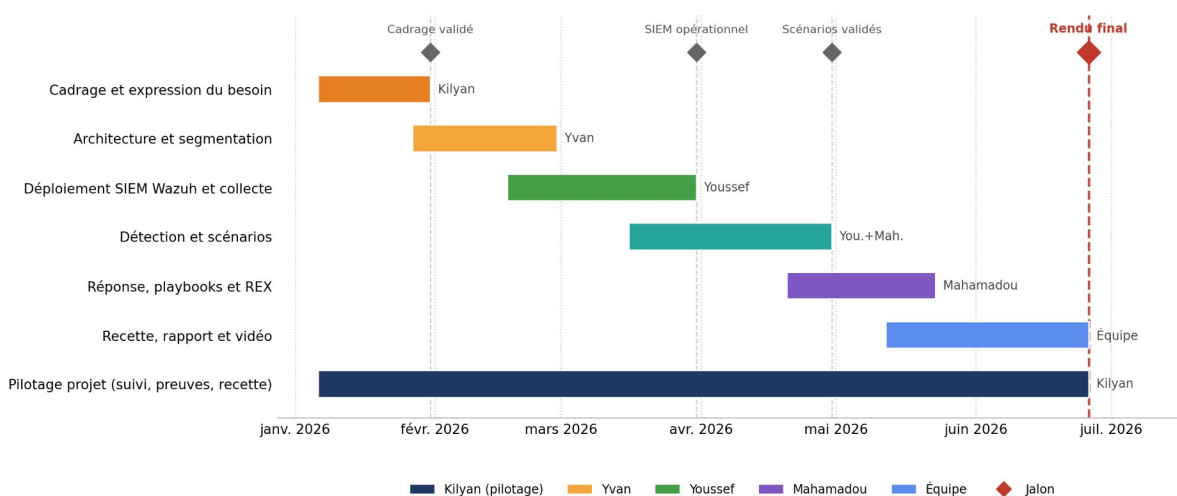


Figure - Planification du projet : lots, dépendances et jalons de janvier à juin 2026.

Le projet a été conduit sur six mois, de janvier à juin 2026, selon une approche hybride et itérative plutôt qu'un cycle séquentiel rigide. Le cadrage initial a fixé le périmètre et les exigences, puis le travail a été découpé en lots livrés et validés de façon incrémentale (architecture, SIEM, détection, réponse, recette), chaque lot s'appuyant sur le précédent. La planification de l'ensemble est présentée dans le diagramme de Gantt ci-dessus.

Le suivi a été organisé en Kanban à l'aide de Jira : chaque lot correspondait à un ticket doté d'un responsable, d'un état d'avancement (À faire / En cours / Terminé) et d'une preuve attendue. Cette visualisation du flux a permis de suivre la progression en continu, d'identifier rapidement les tâches bloquées et de tenir l'échéance du 26 juin 2026.

La méthode repose sur trois principes : une logique de dépendances (l'architecture précède les dashboards, le SIEM précède la qualification), une règle de validation par preuves (une tâche n'est close que si elle produit une configuration, une preuve technique et un élément réutilisable), et des points d'équipe réguliers pour réajuster les priorités. Cette combinaison itératif par lots, suivi Kanban et validation par preuves constitue une démarche agile adaptée à un projet court à fortes dépendances techniques.

☐	Type	Résumé	État	Personne assignée
☐	☒	Lire cahier des charges	TERMINÉ	T tous
☐	☒	Définir architecture	TERMINÉ	Y Yvan
☐	☒	Déployer Wazuh	TERMINÉ	Y Youssef
☐	☒	Intégrer alertes	TERMINÉ	Y Youssef
☐	☒	Formaliser dashboards	TERMINÉ	KF Kilyan Felix
☐	☒	Rédiger playbooks	TERMINÉ	M mahamadou
☐	☒	Préparer vidéo	EN COURS	KF Kilyan Felix
☐	☒	Générer rendu 5 PDF	TERMINÉ	T tous
+ Créer				

Figure - Suivi Kanban Jira : lots projet, responsables, états d'avancement et preuves attendues.

4.1. RACI synthétique

Activité	Kilyan	Yvan	Youssef	Mahamadou
Cadrage client et planning	R/A	C	C	C
Architecture réseau et segmentation	C	R/A	C	C
Déploiement Wazuh et collecte	C	C	R/A	C
Règles de détection et dashboards	A	C	R	R
Playbooks et procédures	C	C	C	R/A
Rapport, vidéo, soutenance	A	R	R	R

R = responsable de production, A = responsable de validation, C = contributeur consulté. Cette lecture clarifie l'organisation sans figer le travail : les membres se sont aidés sur les preuves, les captures et la préparation de la vidéo.

5. Présentation de la solution technique

La solution technique est organisée autour d'un principe directeur : Daylight doit pouvoir confier la supervision de ses événements de sécurité à Cyber Trust tout en conservant une architecture lisible, segmentée et défendable. Le pare-feu structure les flux, Wazuh centralise les événements, les dashboards rendent les alertes exploitables et les playbooks décrivent la réponse attendue.

5.1. Architecture globale et segmentation

L'architecture cible sépare les postes utilisateurs, les serveurs internes, la DMZ applicative, l'administration et le SOC. Cette séparation répond à un besoin client concret : empêcher qu'un incident sur un poste de travail permette d'atteindre directement les serveurs, les outils d'administration ou les composants SOC.

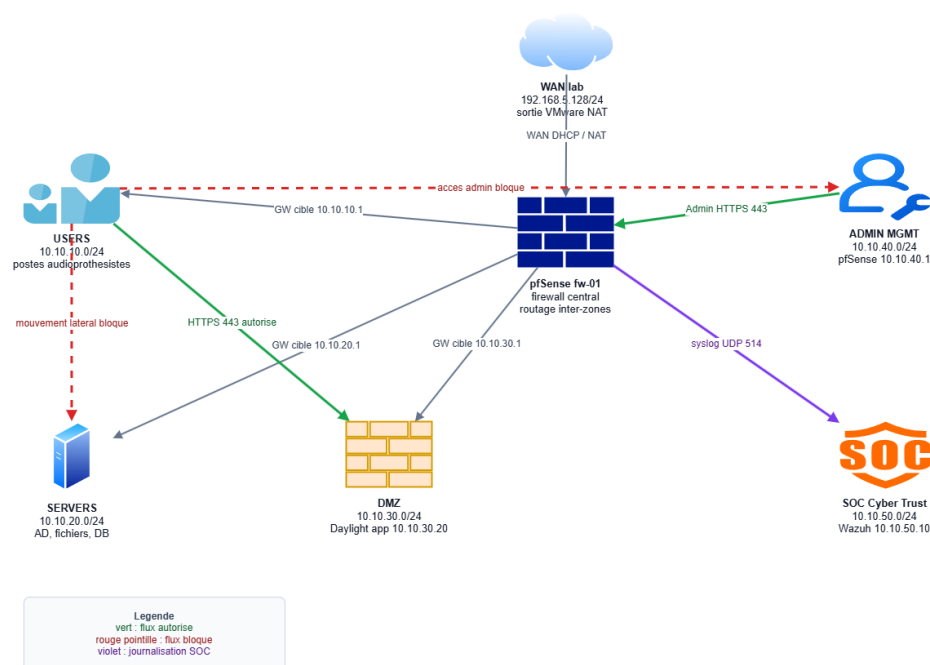


Figure 1 : Architecture globale Daylight / Cyber Trust : segmentation, pfSense, SOC et flux de journalisation.

Zone	Adressage cible	Rôle	Principe de sécurité
USERS	10.10.10.0/24	Postes des audioprothésistes	Accès limité aux services métier et à Internet, sans accès direct aux zones sensibles
SERVERS	10.10.20.0/24	AD, fichiers, base de données	Protection contre le mouvement latéral depuis les postes
DMZ	10.10.30.0/24	Application métier Daylight	Publication applicative isolée du LAN interne
MGMT	10.10.40.0/24	Administration technique	Accès réservé et journalisé
SOC	10.10.50.0/24	Wazuh, dashboard, supervision	Zone protégée contre les accès utilisateurs directs
WAN	192.168.5.128 dans le lab	Sortie externe	Aucune ouverture entrante permissive sans justification

Dans le lab VMware, le périmètre réellement configuré repose sur pfSense avec une interface WAN en 192.168.5.128 et une interface LAN/MGMT en 10.10.40.1. Les autres zones sont formalisées dans les aliases, la matrice d'architecture et les schémas afin de montrer une trajectoire de production cohérente sans surdimensionner le démonstrateur.

5.2. Pare-feu pfSense, flux et journalisation SOC

Cette partie reprend la contribution architecture de Yvan FOCSA. Elle doit être lue comme la base du service : pfSense définit ce qui est autorisé, ce qui est bloqué, et ce qui remonte vers Wazuh. Les captures associées prouvent les interfaces, les alias, les règles LAN/WAN, la journalisation syslog et la remontée des blocages dans le SIEM.

Choix assumé : pfSense n'est pas présenté comme une fin en soi. Il sert surtout à produire une politique réseau lisible et des événements exploitables par Wazuh. C'est ce lien entre filtrage et supervision qui apporte de la valeur au SOC.

La contribution architecture portée par Yvan FOCSA positionne pfSense comme point de contrôle du réseau. Le firewall ne sert pas uniquement à bloquer : il rend les décisions réseau lisibles, force la justification des flux et produit des journaux exploitables par Wazuh. Cette logique est centrale pour un SOC externalisé, car une règle non journalisée peut empêcher la qualification d'un incident.

Les alias pfSense remplacent les adresses IP brutes par des objets métier : ADMIN_SUBNET, SERVERS_SUBNET, SOC_SUBNET, DAYLIGHT_APP, DNS_ALLOWED ou SOC_WAZUH. Cette méthode facilite la maintenance et permet au client de relire une politique de sécurité sans devoir interpréter chaque adresse isolément.

Alias / objet	Valeur utilisée	Usage dans la politique
ADMIN_SUBNET	10.10.40.0/24	Zone d'administration à protéger
SERVERS_SUBNET	10.10.20.0/24	Serveurs internes non accessibles directement depuis les postes
SOC_SUBNET	10.10.50.0/24	Zone Cyber Trust / Wazuh
DAYLIGHT_APP	10.10.30.20	Application métier autorisée en HTTPS
DNS_ALLOWED	10.10.10.1 ; 10.10.20.10	Résolveurs internes autorisés pour les postes utilisateurs
SOC_WAZUH	10.10.50.10	Collecteur Wazuh pour syslog pfSense

La politique LAN suit un ordre volontairement simple : autoriser les flux indispensables, bloquer les zones sensibles, puis autoriser la navigation web contrôlée. L'ordre est important car pfSense évalue les règles de haut en bas : une autorisation trop large placée trop haut pourrait neutraliser les blocages métier.

Ordre	Décision	Source	Destination	Port	Objectif
1	Pass	LAN subnets	DNS_ALLOWED	TCP/UDP 53	Résolution DNS vers des serveurs connus
2	Pass	LAN subnets	DAYLIGHT_APP	TCP 443	Accès HTTPS à l'application Daylight
3	Block	LAN subnets	SERVERS_SUBNET	Any	Limitation du mouvement latéral
4	Block + log	LAN subnets	ADMIN_SUBNET	Any	Protection de la zone d'administration
5	Block + log	LAN subnets	SOC_SUBNET	Any	Empêchement d'un accès direct au SOC
6	Pass	LAN subnets	Internet	TCP 80/443	Navigation web nécessaire

Firewall / Rules / LAN

Floating WAN LAN

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 2/4.06 MIB	*	*	*	LAN Address	443 80	*	*		Anti-Logout Rule	⚙️
☐	✓ 0/0 B	IPv4 TCP/UDP	LAN subnets	*	DNS_ALLOWED	53 (DNS)	*	none		Allow DNS users	📌 ⚙️ 🗑️ ✖️
☐	✓ 0/0 B	IPv4 TCP	LAN subnets	*	DAYLIGHT_APP	443 (HTTPS)	*	none		Allow Daylight app HTTPS	📌 ⚙️ 🗑️ ✖️
☐	✗ 0/0 B	IPv4 TCP	LAN subnets	*	SERVERS_SUBNET	*	*	none		Block lateral movement	📌 ⚙️ 🗑️ ✖️
☐	✗ 0/1 KIB	IPv4 *	LAN subnets	*	ADMIN_SUBNET	*	*	none		Block users to admin zone	📌 ⚙️ 🗑️ ✖️
☐	✗ 0/0 B	IPv4 *	LAN subnets	*	SOC_SUBNET	*	*	none		Block direct users to SOC	📌 ⚙️ 🗑️ ✖️
☐	✗ 0/0 B	IPv4 TCP	LAN subnets	*	*	80 - 443	*	none		Allow web browsing	📌 ⚙️ 🗑️ ✖️

📘

Figure 2 : Règles LAN pfSense : autorisations métier, blocages structurants et navigation contrôlée.

La posture WAN du lab reste restrictive : aucune règle entrante permissive n'est ajoutée. Cette décision est cohérente avec une logique client, car toute publication depuis Internet doit être justifiée, documentée, validée et surveillée. Dans une cible de production, les accès d'administration seraient plutôt traités via VPN et filtrage d'origine.

L'intégration SOC repose sur le remote logging pfSense. Les journaux système, firewall, authentification et gateway sont envoyés vers Wazuh en UDP 514, avec SOC_WAZUH représenté par 10.10.50.10 dans la cible. Cette preuve montre que le firewall devient une source réseau exploitable par le SIEM.

Remote Logging Options

Enable Remote Logging ☒ Send log messages to remote syslog server

Source Address LAN

This option will allow the logging daemon to bind to a single IP address, rather than all IP addresses. If a single IP is picked, remote syslog servers must all be of that IP type. To mix IPv4 and IPv6 remote syslog servers, bind to all interfaces.

NOTE: If an IP address cannot be located on the chosen interface, the daemon will bind to all addresses.

IP Protocol IPv4

This option is only used when a non-default address is chosen as the source above. This option only expresses a preference; if an IP address of the selected type is not found on the chosen interface, the other type will be tried.

Remote log servers 10.10.50.10:514 IP[:port] IP[:port]

Remote Syslog Contents

- ☐ Everything
- ☒ System Events
- ☒ Firewall Events
- ☐ DNS Events (Resolver/unbound, Forwarder/dnsmasq, filterdns)
- ☐ DHCP Events (DHCP Daemon, DHCP Relay, DHCP Client)
- ☐ PPP Events (PPPoE WAN Client, L2TP WAN Client, PPTP WAN Client)
- ☒ General Authentication Events
- ☐ Captive Portal Events
- ☐ VPN Events (IPsec, OpenVPN, L2TP, PPPoE Server)
- ☒ Gateway Monitor Events
- ☐ Routing Daemon Events (RADVD, UPnP, RIP, OSPF, BGP)
- ☐ Network Time Protocol Events (NTP Daemon, NTP Client)
- ☐ Wireless Events (hostapd)

Syslog sends UDP datagrams to port 514 on the specified remote syslog server, unless another port is specified. Be sure to set syslogd on the remote server to accept syslog messages from pfSense.

[Save](#)

Figure 3 : Configuration syslog pfSense vers Wazuh : remote logging activé vers 10.10.50.10:514.

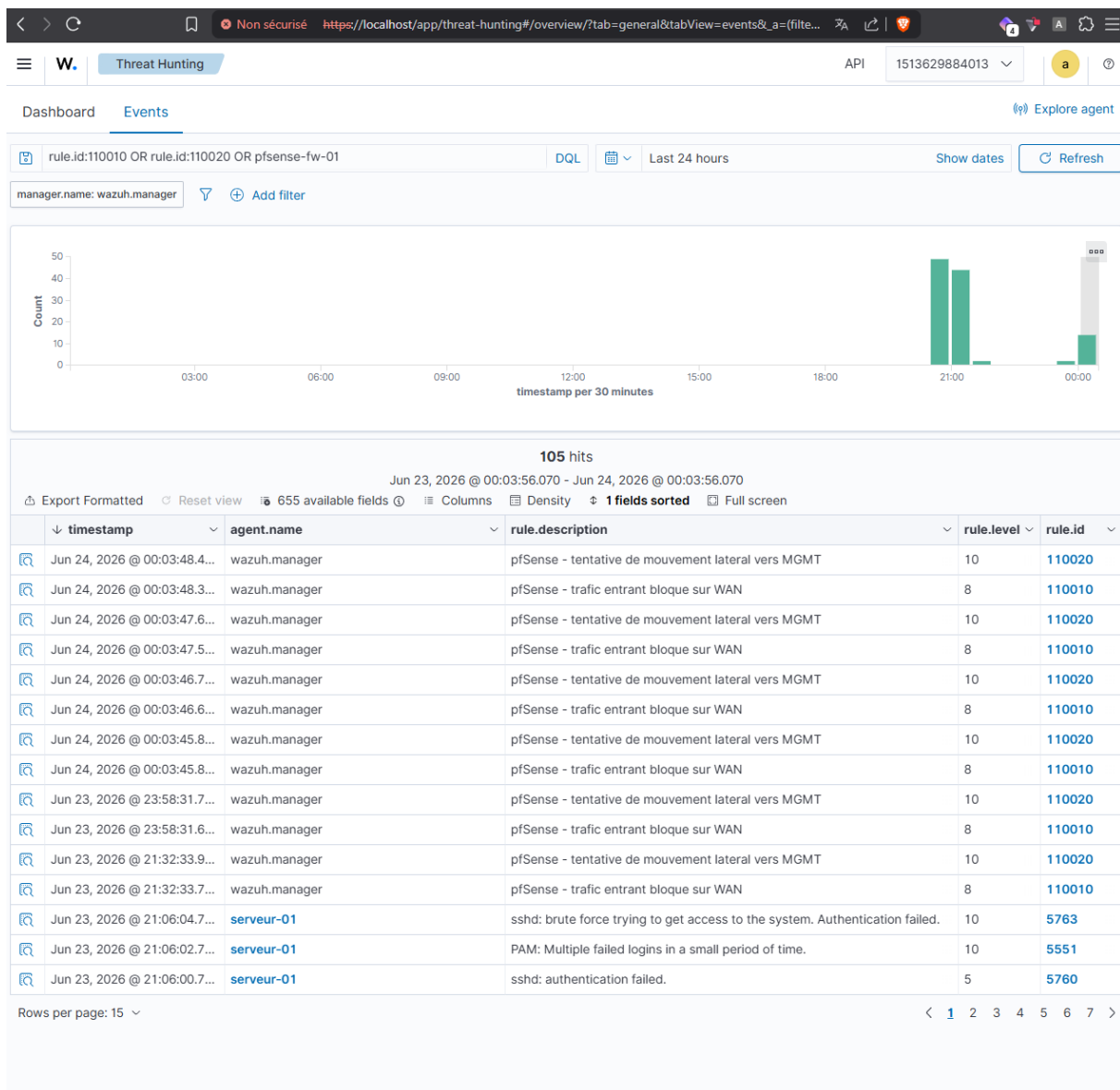


Figure 4 : Wazuh Threat Hunting : événements pfSense visibles avec les règles 110010 et 110020.

Les règles Wazuh associées aux événements pfSense permettent de transformer un refus réseau en événement SOC qualifiable. La règle 110010 couvre le trafic entrant bloqué sur WAN, tandis que la règle 110020 met en évidence une tentative de mouvement latéral vers la zone d'administration. Cela relie directement l'architecture de filtrage à la détection opérationnelle.

5.2.1. Chaîne de preuves pfSense présentée au client

Les captures pfSense ne sont pas présentées comme de simples écrans de configuration. Elles servent à démontrer une chaîne de contrôle complète : le firewall est opérationnel, les interfaces matérialisent les frontières réseau, les objets rendent la politique lisible, les règles appliquent les décisions de sécurité, les journaux prouvent les blocages et Wazuh transforme ces événements en alertes exploitables par le SOC.

Deux supports de conception accompagnent cette démonstration. La matrice [Excel YVAN Architecture Zones Flux pfSense Wazuh.xlsx](#) regroupe les feuilles ZONES_ADRESSAGE, FLUX_REGLES, ALIASES_PFSENSE, INTERFACES_PFSENSE, PORTS_WAZUH et CAPTURES_A_MONTRER. Le fichier [YVAN Schemas Architecture.drawio](#) sert de support graphique pour relier l'architecture globale, les flux pfSense et la chaîne SOC Wazuh. Ces fichiers évitent que la configuration reste dépendante de captures isolées : ils donnent une lecture maintenable et réutilisable par le client.

Preuve A : pfSense opérationnel et interfaces actives

La première preuve rassure le client sur le socle technique : la VM pfSense est démarrée, nommée pfsense-fw-01.daylight.local, et expose bien deux interfaces actives. Le WAN est utilisé pour la connectivité externe du lab, tandis que le LAN/MGMT représente la zone d'administration utilisée pour configurer et superviser le firewall.

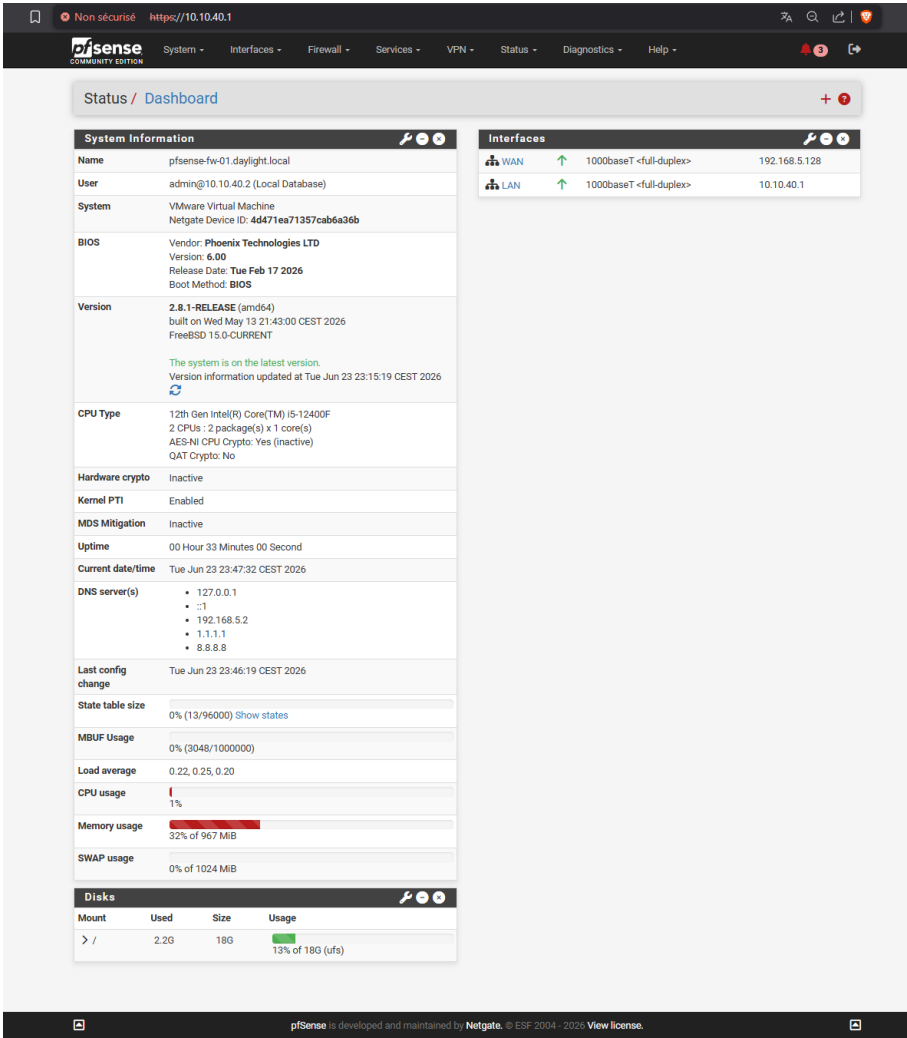


Figure complémentaire : Dashboard pfSense : équipement actif, WAN 192.168.5.128 et LAN 10.10.40.1 visibles.

Preuve B : Affectation WAN/LAN maîtrisée

La capture d'affectation des interfaces confirme que la séparation réseau n'est pas seulement théorique. WAN est porté par em0 et LAN par em1. Pour Daylight, cette distinction est importante car elle matérialise la frontière entre l'extérieur, l'administration et les flux internes qui seront contrôlés par les règles firewall.

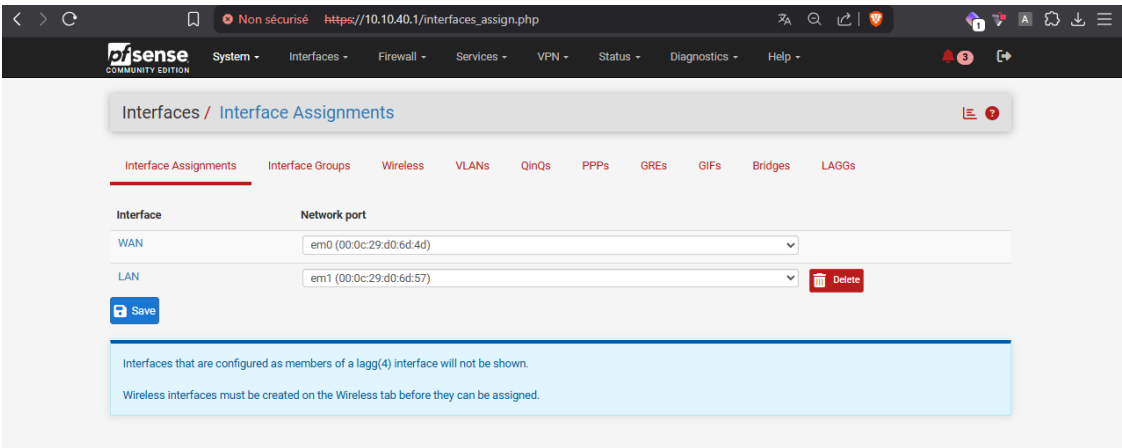


Figure complémentaire : Affectation des interfaces pfSense : WAN sur em0 et LAN sur em1.

Preuve C : Objets réseau lisibles et maintenables

Les aliases pfSense donnent une lecture professionnelle de la politique réseau. Au lieu de manipuler uniquement des adresses IP, le firewall utilise des objets nommés : USERS_SUBNET, SERVERS_SUBNET, DMZ_SUBNET, ADMIN_SUBNET, SOC_SUBNET, SOC_WAZUH, DAYLIGHT_APP ou DNS_ALLOWED. Cette convention facilite l'audit, la maintenance et la reprise par une autre personne.

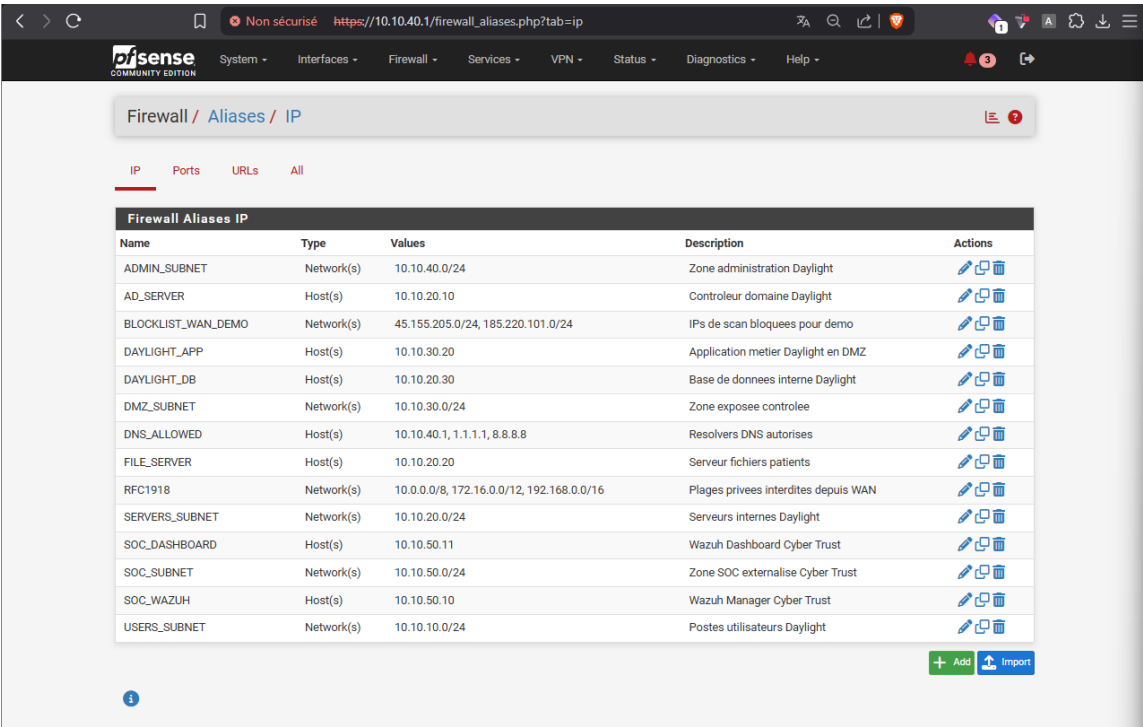


Figure complémentaire : Aliases pfSense : zones, hôtes critiques, Wazuh, application Daylight et résolveurs DNS autorisés.

Preuve D : Posture WAN restrictive

La page WAN montre qu'aucune règle entrante permissive n'a été ajoutée dans le lab. Cette décision est volontaire : le démonstrateur ne cherche pas à ouvrir le firewall pour faciliter la présentation. Il défend une posture de sécurité réaliste où tout flux entrant doit être explicitement justifié, documenté et surveillé.

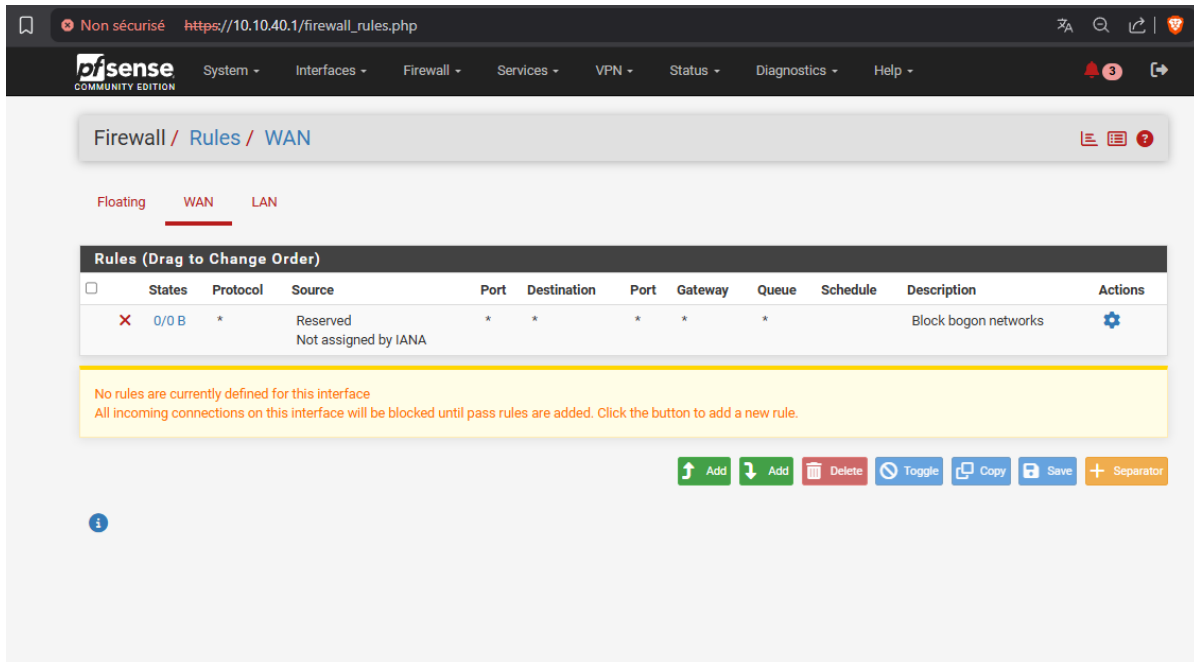
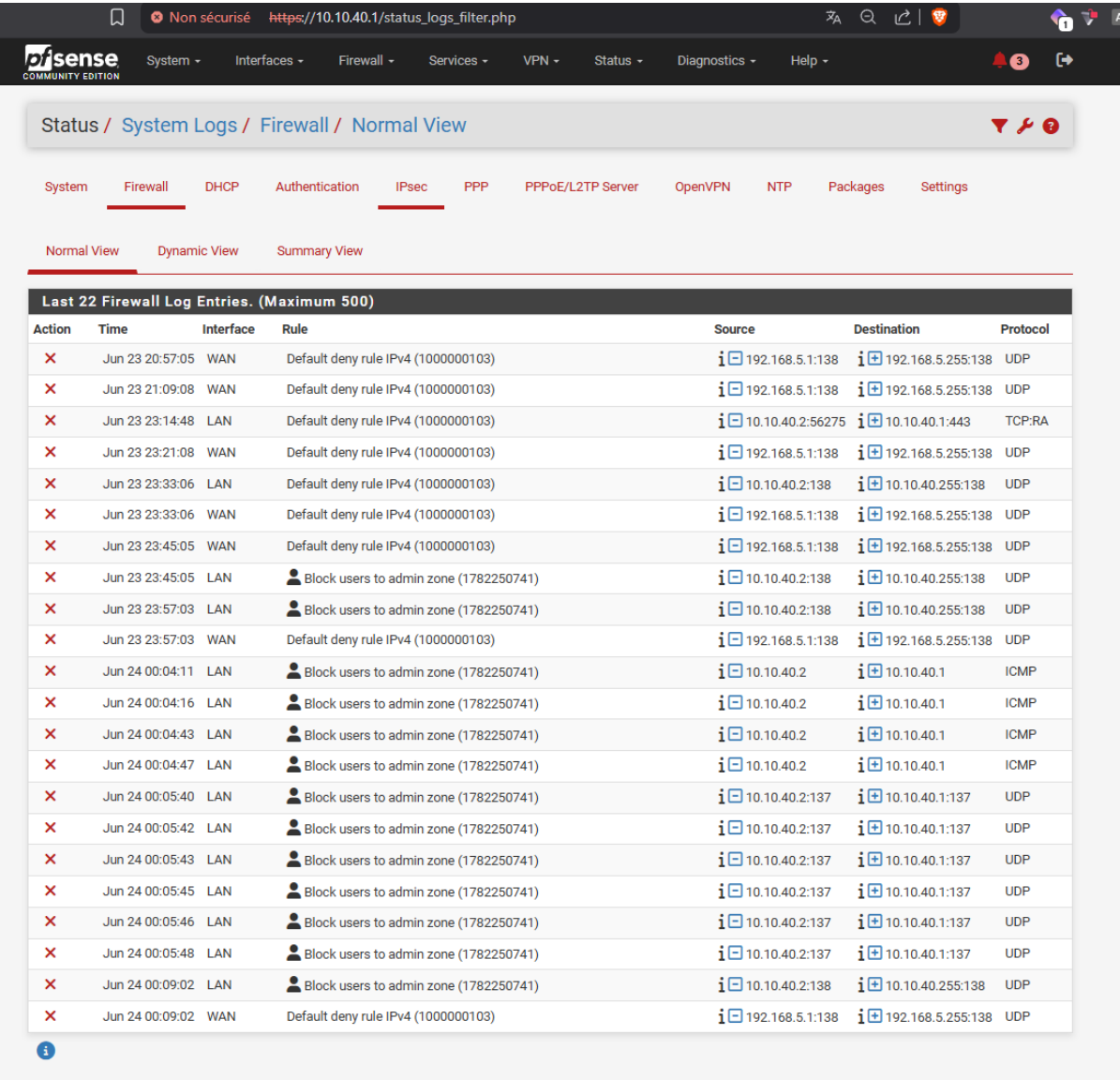


Figure complémentaire : Règles WAN : absence d'ouverture entrante permissive, blocage par défaut conservé.

Preuve E : Blocages journalisés côté firewall

La preuve de logs pfSense montre que les règles produisent des événements exploitables : blocages vers la zone d'administration, refus WAN et traces horodatées. Pour un client, c'est le point clé : une politique de filtrage utile au SOC doit non seulement bloquer, mais aussi produire une preuve consultable et corrélable.



Status / System Logs / Firewall / Normal View

System Firewall DHCP Authentication IPsec PPP PPPoE/L2TP Server OpenVPN NTP Packages Settings

Normal View Dynamic View Summary View

Last 22 Firewall Log Entries. (Maximum 500)

Action	Time	Interface	Rule	Source	Destination	Protocol
×	Jun 23 20:57:05	WAN	Default deny rule IPv4 (1000000103)	192.168.5.1:138	192.168.5.255:138	UDP
×	Jun 23 21:09:08	WAN	Default deny rule IPv4 (1000000103)	192.168.5.1:138	192.168.5.255:138	UDP
×	Jun 23 23:14:48	LAN	Default deny rule IPv4 (1000000103)	10.10.40.2:56275	10.10.40.1:443	TCP:RA
×	Jun 23 23:21:08	WAN	Default deny rule IPv4 (1000000103)	192.168.5.1:138	192.168.5.255:138	UDP
×	Jun 23 23:33:06	LAN	Default deny rule IPv4 (1000000103)	10.10.40.2:138	10.10.40.255:138	UDP
×	Jun 23 23:33:06	WAN	Default deny rule IPv4 (1000000103)	192.168.5.1:138	192.168.5.255:138	UDP
×	Jun 23 23:45:05	WAN	Default deny rule IPv4 (1000000103)	192.168.5.1:138	192.168.5.255:138	UDP
×	Jun 23 23:45:05	LAN	Block users to admin zone (1782250741)	10.10.40.2:138	10.10.40.255:138	UDP
×	Jun 23 23:57:03	LAN	Block users to admin zone (1782250741)	10.10.40.2:138	10.10.40.255:138	UDP
×	Jun 23 23:57:03	WAN	Default deny rule IPv4 (1000000103)	192.168.5.1:138	192.168.5.255:138	UDP
×	Jun 24 00:04:11	LAN	Block users to admin zone (1782250741)	10.10.40.2	10.10.40.1	ICMP
×	Jun 24 00:04:16	LAN	Block users to admin zone (1782250741)	10.10.40.2	10.10.40.1	ICMP
×	Jun 24 00:04:43	LAN	Block users to admin zone (1782250741)	10.10.40.2	10.10.40.1	ICMP
×	Jun 24 00:04:47	LAN	Block users to admin zone (1782250741)	10.10.40.2	10.10.40.1	ICMP
×	Jun 24 00:05:40	LAN	Block users to admin zone (1782250741)	10.10.40.2:137	10.10.40.1:137	UDP
×	Jun 24 00:05:42	LAN	Block users to admin zone (1782250741)	10.10.40.2:137	10.10.40.1:137	UDP
×	Jun 24 00:05:43	LAN	Block users to admin zone (1782250741)	10.10.40.2:137	10.10.40.1:137	UDP
×	Jun 24 00:05:45	LAN	Block users to admin zone (1782250741)	10.10.40.2:137	10.10.40.1:137	UDP
×	Jun 24 00:05:46	LAN	Block users to admin zone (1782250741)	10.10.40.2:137	10.10.40.1:137	UDP
×	Jun 24 00:05:48	LAN	Block users to admin zone (1782250741)	10.10.40.2:137	10.10.40.1:137	UDP
×	Jun 24 00:09:02	LAN	Block users to admin zone (1782250741)	10.10.40.2:138	10.10.40.255:138	UDP
×	Jun 24 00:09:02	WAN	Default deny rule IPv4 (1000000103)	192.168.5.1:138	192.168.5.255:138	UDP

Figure complémentaire : Logs firewall pfSense : blocages LAN vers administration et refus WAN visibles.

Ces preuves complètent les figures déjà intégrées dans le rapport : règles LAN, remote logging vers Wazuh et alertes pfSense visibles dans Wazuh Threat Hunting. L'ensemble démontre que la partie architecture ne se limite pas à un schéma : elle produit des contrôles concrets, des journaux et des événements SOC qualifiables.

5.3. Plateforme SIEM Wazuh et collecte multi-source

La partie SIEM, portée par Youssef GUERNIOU, repose sur Wazuh en mode single-node Docker. Le démonstrateur regroupe les trois briques attendues : Manager pour l'analyse, Indexer pour le stockage et la recherche, Dashboard pour l'interface web. Cette approche rend le lab reproductible et évite les écarts de configuration entre les membres de l'équipe.

Composant Wazuh	Rôle	Port / accès utilisé
Wazuh Manager	Analyse des événements, application des règles, réception agents/syslog	1514/TCP agents, 1515/TCP enrôlement, 514/UDP syslog
Wazuh Indexer	Stockage et recherche des événements	9200/TCP
Wazuh Dashboard	Interface web, dashboards, Threat Hunting et RBAC	443/TCP
Wazuh API	Administration et automatisation possible	55000/TCP

La collecte couvre trois familles de sources, conformément au cahier des charges : un endpoint Windows, un serveur Linux et une application métier Daylight. Cette diversité est importante car un SOC ne peut pas reposer uniquement sur les logs système : il doit aussi intégrer les événements réseau et les événements applicatifs liés au métier.

Source	Exemple démontré	Valeur SOC
Endpoint Windows poste-01	Agent Wazuh, conformité CIS Windows 11, événements Windows	Visibilité endpoint et audit de durcissement
Serveur Linux serveur-01	auth.log, SSH, force brute, règles 5503/5712	Détection d'attaque sur serveur exposé
Application métier Daylight	Accès dossier patient, brute force, modification groupe, USB	Détection contextualisée métier santé
pfSense	Syslog firewall, blocages WAN/LAN	Corrélation réseau avec les alertes SIEM

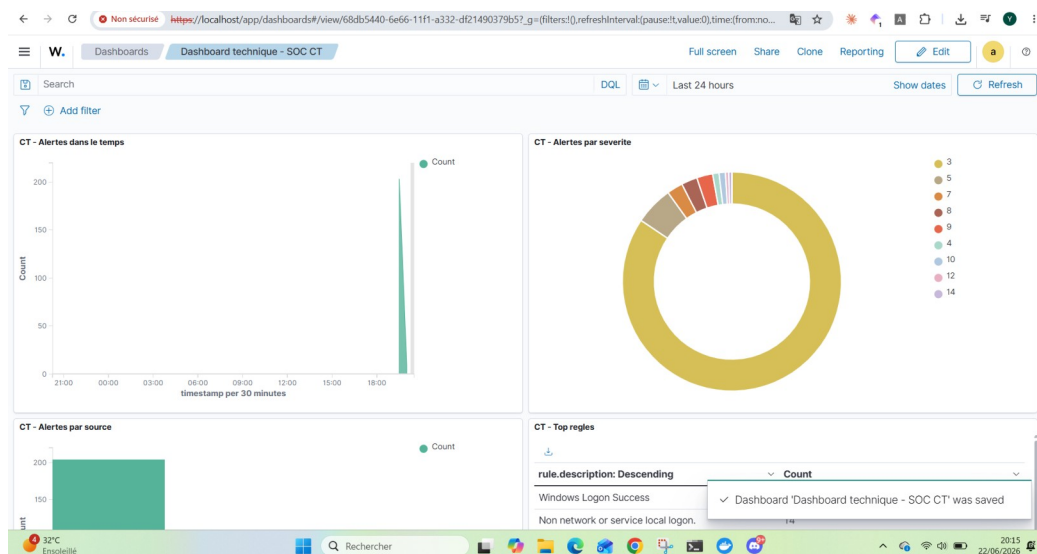


Figure 5 : Dashboard technique Wazuh : alertes dans le temps, sévérité, source et top règles.

Deux vues complémentaires ont été prévues. Le dashboard technique sert aux analystes et à l'équipe SOC : il met l'accent sur les sources, les règles et la sévérité. Le dashboard exécutif sert à la lecture client : il synthétise le nombre d'alertes, les alertes critiques et la répartition par site.

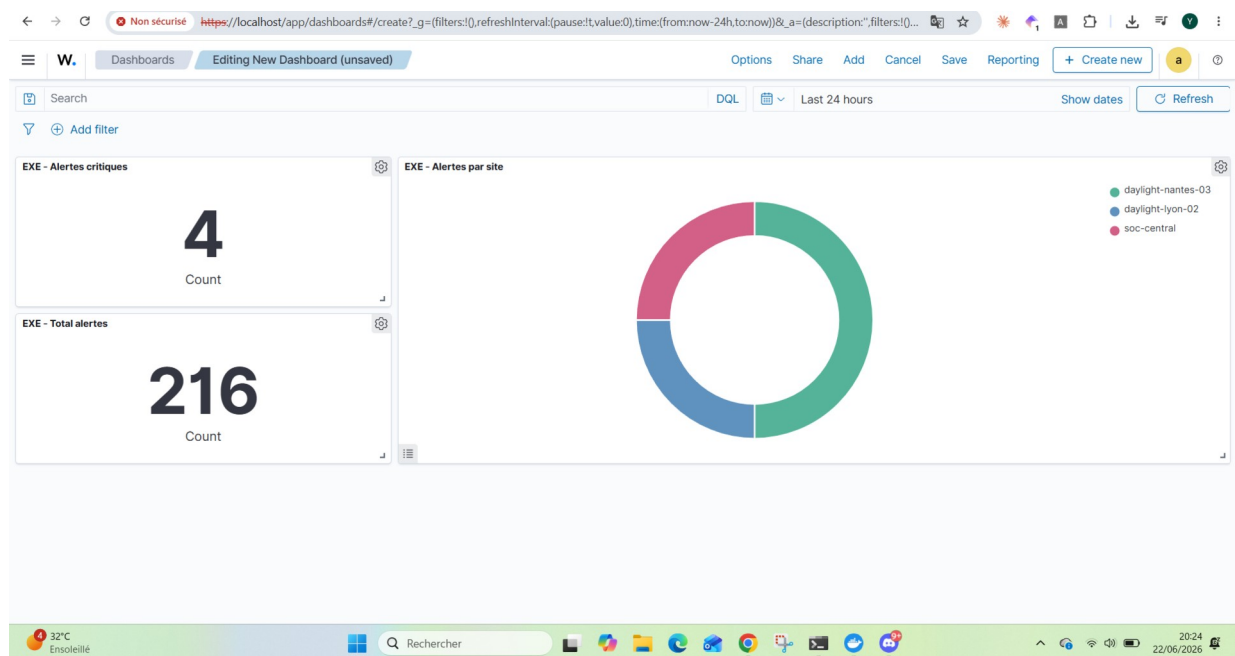


Figure 6 : Dashboard exécutif Wazuh : total d'alertes, alertes critiques et répartition par site.

La segmentation par rôles est également couverte. Les profils admin, analyste et supervision répondent à l'exigence d'interface web accessible et segmentée. L'administrateur conserve les droits complets, tandis que les profils analyste et supervision disposent d'un accès en lecture adapté aux dashboards et aux alertes.

Profil	Droits attendus	Usage
Admin	Configuration complète et administration sécurité	Maintien de la plateforme et gestion RBAC
Analyste	Lecture alertes, qualification, Threat Hunting	Traitement opérationnel des incidents
Supervision	Lecture dashboards et synthèse	Suivi client et pilotage quotidien

5.3.1. Collecte SIEM : la brique centrale du SOC

La partie portée par Youssef GUERNIOU est la brique centrale du démonstrateur. Sans collecte Wazuh stable, les dashboards, les playbooks et la qualification SOC ne sont pas défendables. Le SIEM transforme les événements techniques en matière exploitable pour l'analyste et pour le client.

Le choix de Wazuh en single-node reste adapté au MVP : il regroupe Manager, Indexer et Dashboard dans un environnement simple à relancer, tout en prouvant la chaîne attendue en production : réception, corrélation, indexation, recherche et restitution.

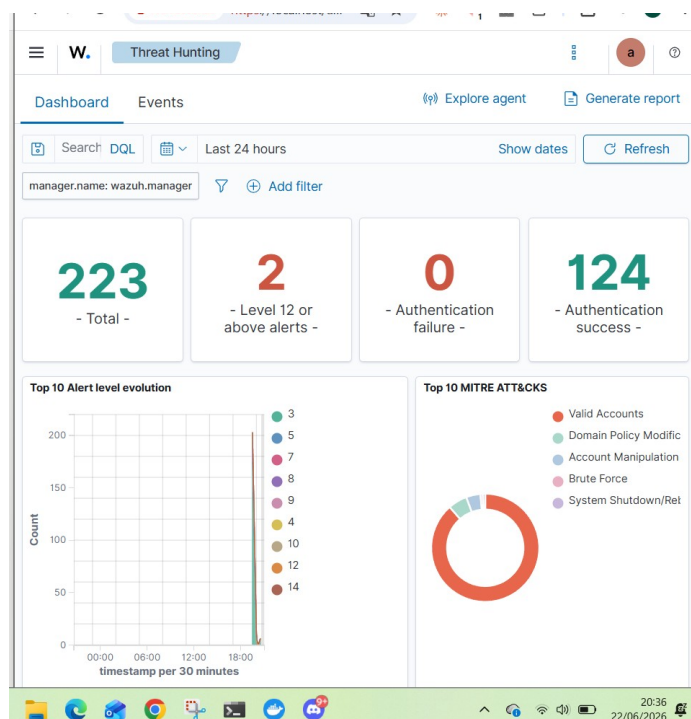


Figure - Vue d'ensemble Wazuh : le SOC dispose d'une lecture centralisée des alertes, authentifications et tendances MITRE.

5.3.2. Collecte multi-source et reproductibilité du lab

La collecte ne se limite pas à un seul serveur. Le démonstrateur raccorde un endpoint, un serveur Linux, les logs métier Daylight et les événements pfSense. Cette variété est importante pour un client : elle montre que Cyber Trust sait corréler les signaux issus du poste, du réseau et de l'application métier.

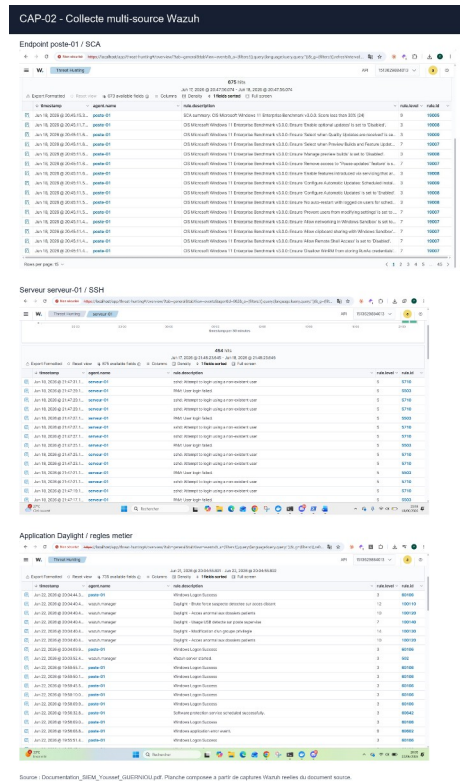


Figure - Collecte multi-source Wazuh : endpoint, serveur SSH et application Daylight visibles dans la même chaîne SIEM.

CAP-15 - Automatisation lab SIEM

Script Youssef : serveur-01, agent Wazuh, SSH/rsyslog, brute force 5712

Pipeline script

```
# setup-siem-lab.ps1 -- Perimetre Ingenieur SIEM (Youssef GUERINIOU)
#
# Reproduit en UNE commande la partie SIEM du lab SOC :
# 1. serveur-01 : conteneur Linux + agent Wazuh + SSH/rsyslog
#    + fix auth.log + test brute force (5712)
# 2. RBAC : utilisateurs supervision / analyste + role
#    lecture seule "soc_readonly" + mapping
# 3. (optionnel) : source applicative Daylight via les scripts npm
#
# PREREQUIS : Docker Desktop lance + lab Wazuh démarre
#             (npm run lab.start). A lancer depuis la racine du projet.
#
# USAGE : .\scripts\setup-siem-lab.ps1
#
$ErrorActionPreference = "Stop"
$serverContainer = "serveur-01"
$indexerContainer = "single-node-wazuh-indexer-1"

function Write-Step($msg) { Write-Host "n== $msg ==n" -ForegroundColor Cyan }

#
# 0. Verification Docker
...
```

Source : Youssef GUERINIOU/setup-siem-lab.ps1
Preuve documentaire generée depuis les livrables du dossier ; elle ne pretend pas être une capture live d'un outil.

Figure - Script de lab SIEM : automatisation serveur-01, agent Wazuh, SSH/rsyslog et brute force 5712.

5.4. Détection, qualification et scénarios de preuve

Nous avons privilégié des scénarios courts à expliquer : force brute, accès patient, privilège, USB et mouvement latéral. Ils ne couvrent pas tout le spectre d'attaque, mais ils prouvent la chaîne détection -> qualification -> action.

Les scénarios de détection ont été choisis pour couvrir les risques les plus compréhensibles pour Daylight : force brute SSH, accès anormal à un dossier patient, usage USB, modification de privilèges et trafic réseau bloqué. Chaque scénario est défendable devant un client car il correspond soit à un risque métier, soit à un comportement d'attaque fréquent.

Scénario	Source	Règle / alerte	Priorité SOC
Force brute SSH	serveur-01	5712 / niveau 10	Élevée : compromission possible d'un serveur
Accès anormal dossier patient	Application Daylight	100120 / niveau 12	Critique : donnée sensible et risque RGPD
Brute force accès distant	Application Daylight	100110 / niveau 10	Critique : tentative d'accès non autorisé
Modification groupe privilégié	Application Daylight	100130 / niveau 12	Critique : élévation de privilèges
Usage USB	Endpoint / logs métier	100140 / niveau 8	Moyenne : risque exfiltration ou malware
Blocage WAN pfSense	Firewall	110010 / niveau 8	Élevée : exposition réseau observée
Mouvement latéral vers MGMT	Firewall	110020 / niveau 10	Critique : tentative vers zone d'administration

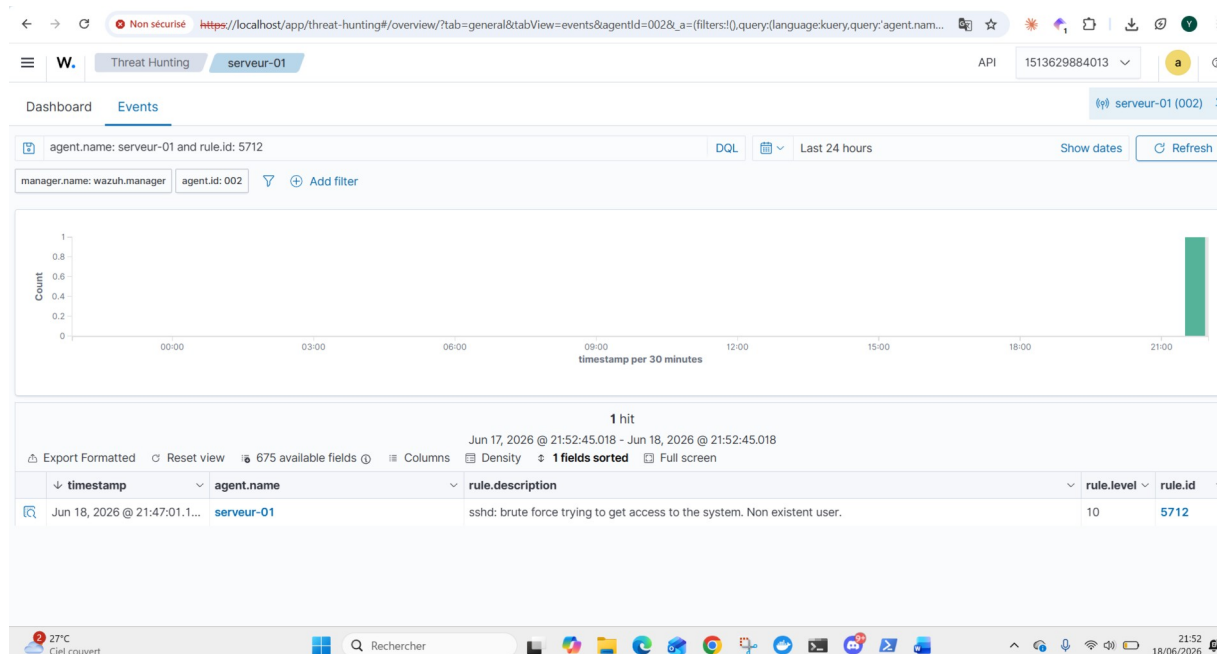


Figure 7 : Détection SSH : alerte de force brute sur serveur-01 avec la règle 5712.

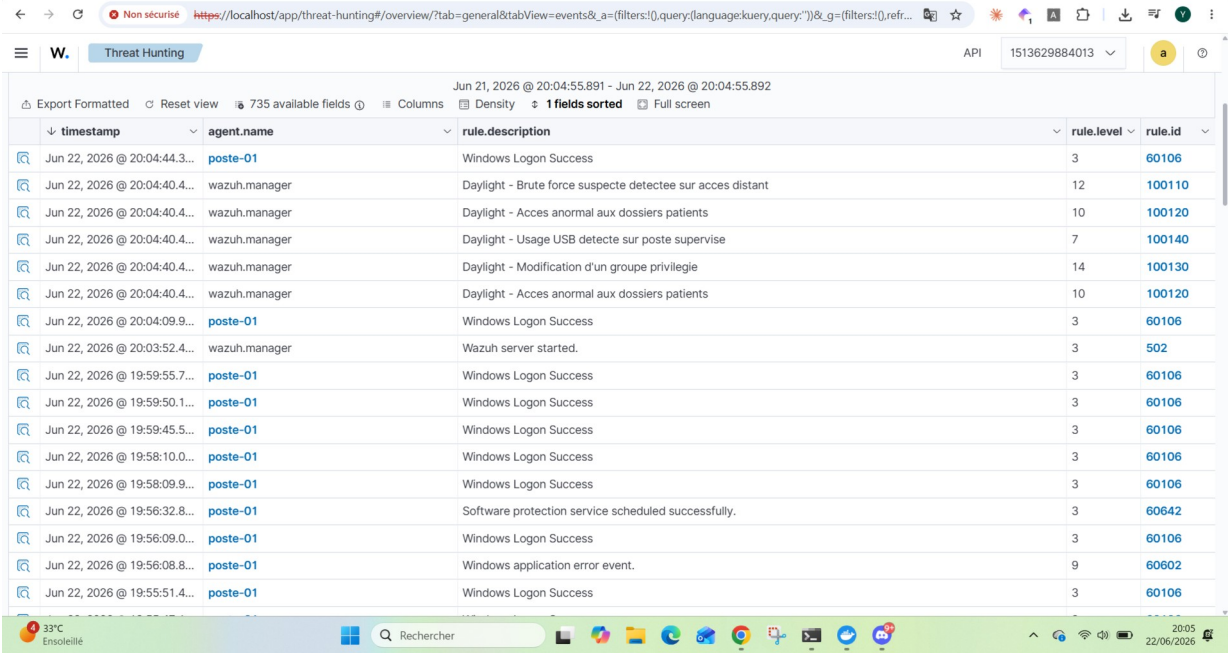


Figure 8 : Alertes métier Daylight : accès patient, brute force, privilèges et USB.

La qualification des alertes ne se limite pas au niveau de sévérité. L'équipe doit lire la source, la règle, le contexte métier et les événements proches. Par exemple, une modification de groupe privilégié peut être légitime si elle correspond à un changement planifié, mais elle devient critique si elle apparaît hors fenêtre de maintenance ou après une série d'échecs d'authentification.

Niveau	Traitement attendu	Exemple projet
Information / faible	Conserver pour tendance et corrélation	Événements Windows standards
Moyen	Vérifier la répétition et le contexte	Usage USB ou erreurs applicatives
Élevé	Qualifier rapidement et documenter	Blocage WAN, force brute SSH
Critique	Escalade immédiate et playbook	Accès patient anormal ou élévation de privilèges

5.4.1. Priorisation métier et qualification des alertes

La partie Kilyan complète la partie SIEM : une alerte n'a de valeur que si elle est priorisée. Les scénarios ont donc été classés selon l'impact métier et l'urgence de réaction. Les accès patients, les modifications de privilèges et les mouvements latéraux sont traités avant les signaux de simple surveillance.

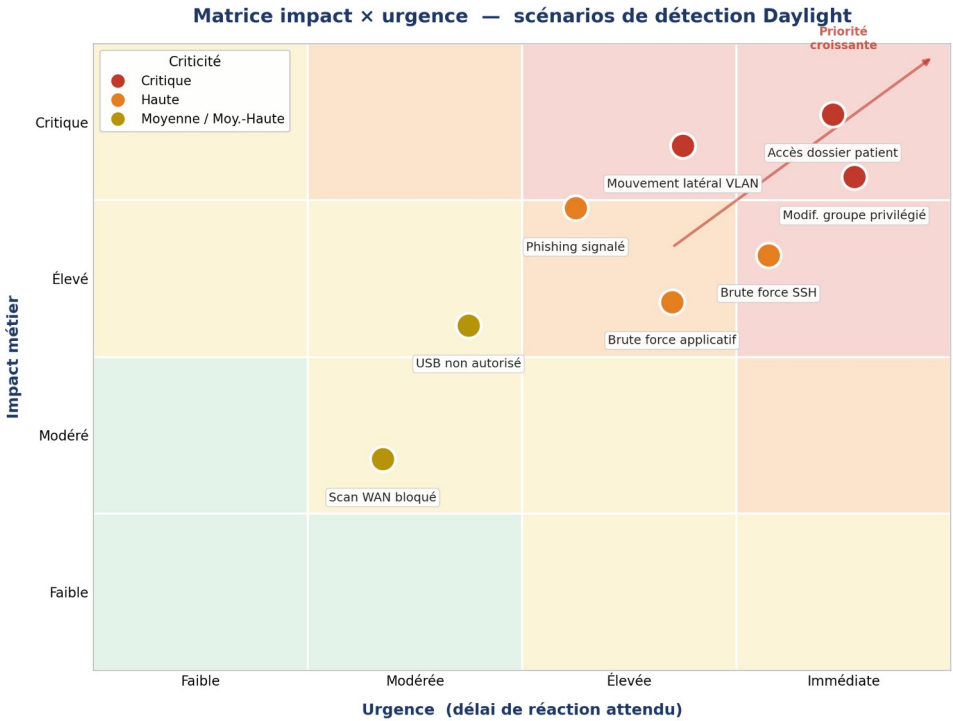


Figure - Matrice impact x urgence : passage d'une alerte technique à une priorité SOC exploitable.

Niveau	Critères	Délai de triage	Décision attendue
Critique	Données patients, privilèges, mouvement latéral, exfiltration	15 min	Escalade immédiate
Haute	Attaque active ou compromission possible	30 min	Qualification prioritaire
Moyenne	Suspicion à contextualiser	4 h	Analyse et suivi
Basse	Hygiène ou information	J+1	Amélioration continue

Cette matrice donne une règle de décision commune : Wazuh détecte, mais le SOC décide selon la criticité, le contexte métier et la preuve disponible.

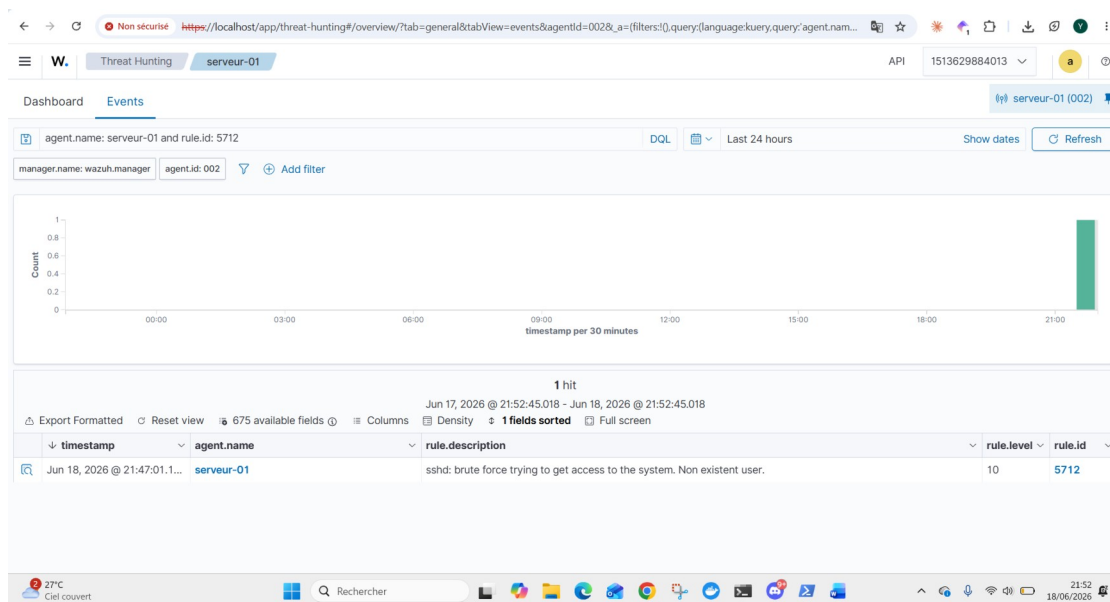


Figure - Alerte Daylight 100120 : accès anormal à un dossier patient, prioritaire car lié aux données sensibles.

The screenshot shows the Threat Hunting interface with a list of alerts. The table below represents the data shown in the interface.

timestamp	agent.name	rule.description	rule.level	rule.id
Jun 22, 2026 @ 20:04:44.3...	poste-01	Windows Logon Success	3	60106
Jun 22, 2026 @ 20:04:40.4...	wazuh.manager	Daylight - Brute force suspecte detectee sur acces distant	12	100110
Jun 22, 2026 @ 20:04:40.4...	wazuh.manager	Daylight - Acces anormal aux dossiers patients	10	100120
Jun 22, 2026 @ 20:04:40.4...	wazuh.manager	Daylight - Usage USB detecte sur poste supervise	7	100140
Jun 22, 2026 @ 20:04:40.4...	wazuh.manager	Daylight - Modification d'un groupe privilegie	14	100130
Jun 22, 2026 @ 20:04:40.4...	wazuh.manager	Daylight - Acces anormal aux dossiers patients	10	100120
Jun 22, 2026 @ 20:04:09.9...	poste-01	Windows Logon Success	3	60106
Jun 22, 2026 @ 20:03:52.4...	wazuh.manager	Wazuh server started.	3	502
Jun 22, 2026 @ 19:59:55.7...	poste-01	Windows Logon Success	3	60106
Jun 22, 2026 @ 19:59:50.1...	poste-01	Windows Logon Success	3	60106
Jun 22, 2026 @ 19:59:45.5...	poste-01	Windows Logon Success	3	60106
Jun 22, 2026 @ 19:58:10.0...	poste-01	Windows Logon Success	3	60106
Jun 22, 2026 @ 19:58:09.9...	poste-01	Windows Logon Success	3	60106
Jun 22, 2026 @ 19:56:32.8...	poste-01	Software protection service scheduled successfully.	3	60642
Jun 22, 2026 @ 19:56:09.0...	poste-01	Windows Logon Success	3	60106
Jun 22, 2026 @ 19:56:08.8...	poste-01	Windows application error event.	9	60602
Jun 22, 2026 @ 19:55:51.4...	poste-01	Windows Logon Success	3	60106

Figure - Vue détaillée Wazuh : contrôle de la source, de la règle, du niveau et du contexte d'indexation.

CAP-19 - Alerting pfSense

Evenements firewall concrets et regles Wazuh 110010/110020/110050

Logs pfSense demo

```

2026-06-23T09:14:02+02:00 pfsense-fw-01 filterlog: action=block interface=WAN src=45.155.205.12 src_zone=Internet
dst=203.0.113.10 dst_zone=WAN proto=tcp dst_port=22 rule=20 msg="WAN scan blocked"
2026-06-23T09:15:17+02:00 pfsense-fw-01 filterlog: action=block interface=USERS src=10.10.10.54 src_zone=USERS dst=10.10.40.12
dst_zone=MGMT proto=tcp dst_port=443 rule=130 msg="User VLAN to management denied"
2026-06-23T09:16:41+02:00 pfsense-fw-01 filterlog: action=pass interface=WAN src=198.51.100.22 src_zone=Internet dst=10.10.30.20
dst_zone=DMZ proto=tcp dst_port=443 rule=40 msg="HTTPS to Daylight portal"
2026-06-23T09:18:09+02:00 pfsense-fw-01 event=vpn_login user=yvan.focsa src=198.51.100.50 result=success mfa=true
2026-06-23T09:20:32+02:00 pfsense-fw-01 filterlog: action=pass interface=SERVERS src=10.10.20.30 src_zone=SERVERS
dst=91.199.212.40 dst_zone=Internet proto=tcp dst_port=443 bytes=84233121 tag=WAN_EXFIL_DEMO msg="High outbound transfer demo"

```

Qualification

```

rule_id=110010 | scenario=Scan WAN bloque | severity=Medium | sla_triage=4 h | first_checks=src IP; dst port; repeat count;
geolocation if available | immediate_action=Monitor and block if persistent | escalation=SOC monitoring | proof=pfSense
filterlog + Wazuh alert
rule_id=110020 | scenario=Inter-VLAN vers MGMT/SERVERS | severity=Critical | sla_triage=15 min | first_checks=source host;
destination zone, port; repetitions | immediate_action=Confirm pfSense block; isolate source host if suspicious | escalation=SOC
+ network exploitation | proof=pfSense rule + Wazuh alert
rule_id=110050 | scenario=Flux sortant volumineux | severity=Critical | sla_triage=15 min | first_checks=source server;
destination IP, bytes; process/app context | immediate_action=Block destination if suspicious; investigate exfiltration |
escalation=SOC + network + Daylight referent | proof=pfSense log + Wazuh alert

```

Source : Demo_Logs/pfsense.log + config/wazuh/local_rules_daylight_pfsense.xml
 Preuve documentaire generée depuis les livrables du dossier ; elle ne pretend pas être une capture live d'un outil.

Figure - Qualification pfSense dans Wazuh : les blocages réseau deviennent des alertes traitables par le SOC.

5.5. Exploitation SOC, playbooks et retour d'expérience

La contribution exploitation, portée par Mahamadou DIACOUMBA, donne à la plateforme SOC une dimension opérationnelle. Pour Daylight, l'objectif n'est pas uniquement de recevoir des alertes dans Wazuh, mais de disposer d'un mode de traitement clair : comprendre le signal, décider du niveau d'urgence, conserver les preuves, prévenir les bons interlocuteurs et capitaliser après incident. Cette partie complète l'architecture réseau portée par Yvan FOCSA et la collecte SIEM portée par Youssef GUERNIOU.

Le périmètre livré est volontairement concret et adapté au démonstrateur. Les playbooks couvrent les scénarios prioritaires du cahier des charges : force brute SSH, accès anormal aux dossiers patients, élévation de privilèges, usage de supports amovibles et tentative de mouvement latéral bloquée par pfSense. Les procédures d'exploitation assurent que le lab peut être relancé, vérifié et présenté de manière reproductible. Les REX transforment les tests en actions d'amélioration pour une future exploitation en production.

5.5.2. Playbooks de réponse aux incidents

Les playbooks ne sont pas rédigés comme de simples fiches théoriques. Ils décrivent ce que l'analyste doit vérifier, dans quel ordre, et quelle sortie produire pour le client. Cette approche rend la réponse répétable, y compris si l'analyste qui traite l'alerte n'est pas celui qui a construit la règle de détection.

Playbook	Signal de déclenchement	Actions SOC attendues	Critère d'escalade
Force brute SSH	Multiples échecs SSH sur serveur-01, alertes Wazuh de niveau élevé.	Identifier l'IP source, le compte visé, rechercher une connexion réussie après les échecs, demander le blocage si nécessaire.	Connexion réussie après l'attaque, compte sensible visé ou source interne récurrente.
Accès anormal dossier patient	Volume inhabituel d'accès aux fichiers patients ou accès depuis un compte non habilité.	Contrôler l'utilisateur, l'heure, le volume, la justification métier et conserver les journaux utiles.	Données patients potentiellement compromises ou absence de justification métier.
Élévation de privilèges	Ajout à un groupe privilégié, usage sudo suspect ou modification de droits.	Comparer avec les changements planifiés, vérifier la persistance, retirer les droits non justifiés.	Modification non autorisée, compte compromis ou action hors fenêtre de maintenance.
Mouvement latéral pfSense	Blocage USERS vers MGMT ou SOC, visible dans pfSense et Wazuh avec les règles réseau.	Identifier source/destination, fréquence, poste concerné, puis renforcer la surveillance ou isoler le poste.	Tentatives répétées ou accès vers une zone d'administration/SOC.
Usage USB suspect	Événement endpoint indiquant un branchement ou usage non conforme.	Identifier le poste, l'utilisateur, le contexte métier et croiser avec les alertes de fichiers sensibles.	Copie de données sensibles ou usage hors politique de sécurité.

5.5.3. Qualification des alertes et niveaux de décision

La qualification est le point où l'analyste transforme une information technique en décision. Pour limiter le bruit, Cyber Trust ne traite pas toutes les alertes de la même manière. Les événements faibles sont journalisés et utilisés pour l'historique ; les événements élevés déclenchent une analyse immédiate ; les événements critiques imposent une escalade. Cette grille donne au client une méthode stable et défendable.

Niveau observé	Lecture opérationnelle	Traitement recommandé
3 à 6	Événement informatif ou faible, utile pour comprendre le contexte.	Conservation dans Wazuh, corrélation possible, pas d'action immédiate sauf répétition.
7 à 9	Signal à investiguer, pouvant révéler un comportement anormal.	Analyse dans la demi-journée, vérification de la source et du contexte métier.
10 à 12	Alerte prioritaire, incident possible ou action interdite observée.	Application du playbook, collecte de preuves, décision de confinement si nécessaire.
13 et plus	Incident critique ou impact potentiel fort.	Escalade immédiate, notification responsable client, conservation renforcée des preuves.

Dans le démonstrateur, cette logique est visible sur les scénarios testés : les alertes SSH de niveau élevé imposent une investigation immédiate ; les événements pfSense liés aux accès MGMT/SOC démontrent que la segmentation bloque le flux et que le SOC dispose d'une trace exploitable ; les alertes liées aux dossiers patients sont traitées avec une priorité renforcée en raison de la sensibilité RGPD.

5.5.4. Procédures d'exploitation du démonstrateur

La procédure d'exploitation garantit que la démonstration reste reproductible. Elle décrit les contrôles à réaliser avant une session, les services à vérifier et les tests de bout en bout à lancer. Ce point est important dans une logique client : un environnement de SOC ne doit pas dépendre de la mémoire d'un membre de l'équipe, mais d'un mode opératoire transmissible.

Contrôles avant démonstration

Avant une soutenance ou une session client, le lab doit être vérifié comme un environnement d'exploitation, pas seulement ouvert au dernier moment. Les contrôles suivants suffisent à confirmer que la démonstration est présentable.

- Vérifier que Wazuh Manager, Indexer et Dashboard sont accessibles.

- Confirmer que les sources attendues remontent des événements récents.

- Relancer SSH, rsyslog et l'agent Wazuh sur serveur-01 si le conteneur a été éteint.

- Vérifier pfSense : interfaces, règles, remote syslog et logs firewall.

- Déclencher un scénario connu puis vérifier l'alerte et le playbook associé.

5.5.5. Retours d'expérience et amélioration continue

Les REX formalisés par Mahamadou DIACOUMBA servent à passer d'une démonstration technique à une démarche d'amélioration continue. Chaque scénario a été relu selon trois angles : ce qui a bien fonctionné, la limite observée et l'action d'amélioration à prévoir pour une future production. Cette approche est cohérente avec un modèle d'infogérance, car le SOC doit progresser au fil des incidents et des usages réels du client.

Retours d'expérience

Les REX montrent que l'équipe n'a pas seulement cherché à obtenir une capture. Chaque scénario a été relu selon ce qui fonctionne, ce qui reste fragile et ce qu'il faudrait améliorer pour une production.

- Force brute SSH : détection rapide, mais blocage encore manuel ; une active response contrôlée serait à étudier.

- Accès dossier patient : l'alerte est prioritaire, mais l'impact réel doit être enrichi par du contexte métier ou DLP.

- Élévation de privilèges : détection efficace, à relier à un processus de changement pour éviter les faux positifs.

- Mouvement latéral pfSense : segmentation et logs cohérents, à enrichir avec DHCP/AD pour afficher l'utilisateur ou le poste.

À court terme, ces actions restent opérées manuellement afin de garder le démonstrateur simple et contrôlable. En trajectoire de production, elles pourront être raccordées à un outil de ticketing ou à une brique SOAR légère, par exemple TheHive, Shuffle ou Cortex, pour suivre les incidents, affecter les tâches et conserver l'historique de traitement. Ces outils sont donc présentés comme une évolution industrialisable, pas comme une dépendance obligatoire du MVP.

5.5.6. Valeur apportée au client

La valeur de cette contribution est de rendre la solution exploitable par une équipe SOC et compréhensible par Daylight. Les alertes deviennent des cas de traitement, les cas de traitement deviennent des procédures, et les procédures alimentent les retours d'expérience. Cette structuration permet à Cyber Trust de démontrer au client non seulement que les événements sont collectés, mais aussi qu'ils peuvent être traités avec méthode, preuves et traçabilité.

5.5.7. Exploitation client : RBAC, rejeu et reporting

Pour Daylight, la sécurité d'exploitation compte autant que la détection. Le démonstrateur prouve donc trois points : les profils ne disposent pas tous des mêmes droits, les événements peuvent être rejoués pour tester la chaîne, et les dashboards donnent une lecture différente selon le public.

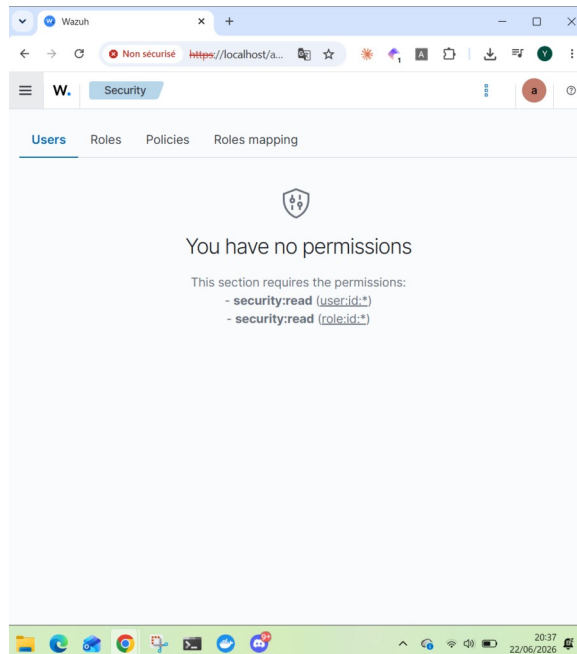


Figure - RBAC Wazuh : un profil analyste en lecture seule ne peut pas modifier la configuration sécurité.

CAP-20 - Rejeu logs vers Wazuh
 Mode dry-run : les événements sont prêts à être envoyés en syslog

Synthese fichiers logs

ad_files.log: 3 événement(s)
 daylight_app.log: 4 événement(s)
 endpoint_usb.log: 2 événement(s)
 mail_phishing.log: 2 événement(s)
 pfsense.log: 5 événement(s)
 Total dry-run: 16 événement(s) prêts à rejouer

Extrait dry-run

=== Rejeu logs demo Daylight / Cyber Trust ===
 Dossier logs : C:\Users\lvan\Pictures\PROJET M2\Demo_Logs
 Cible : UDP 127.0.0.1:514
 Evenements : 16

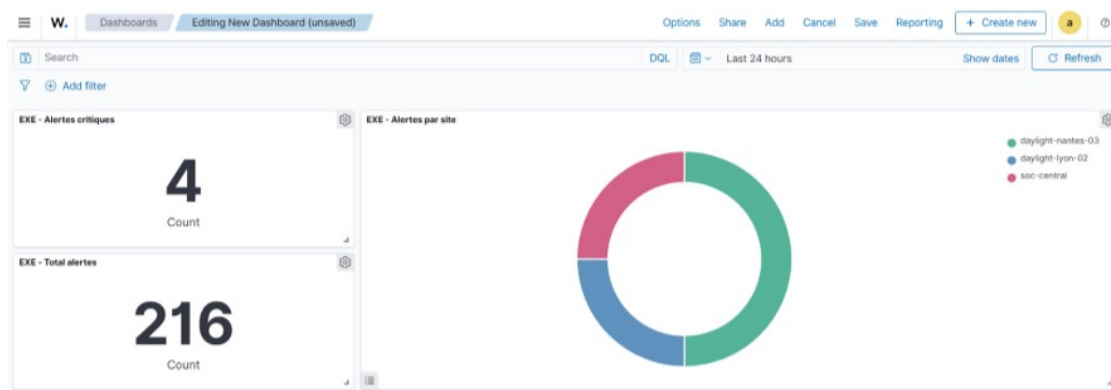
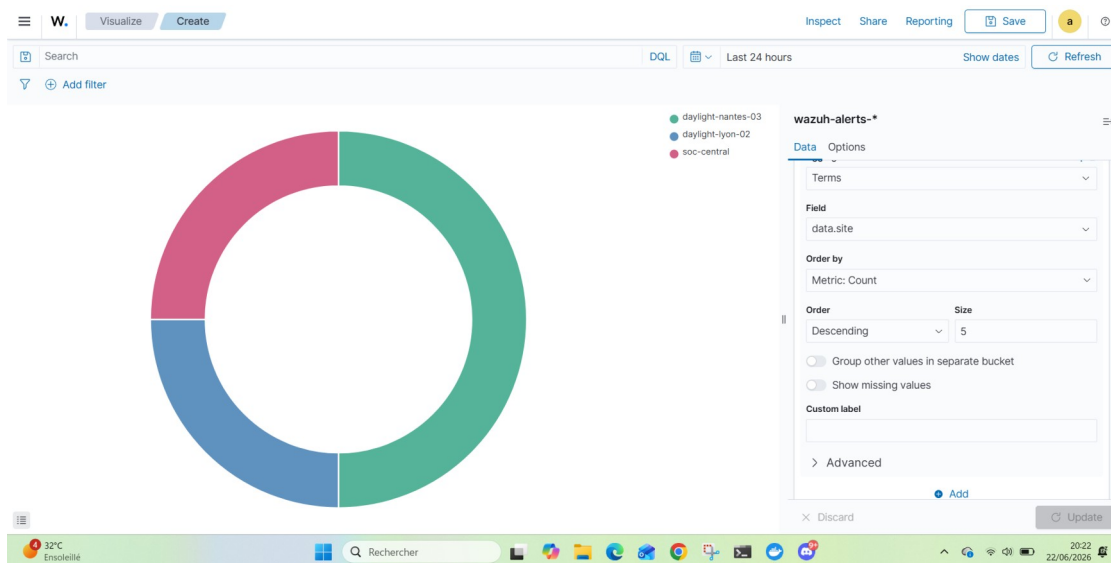
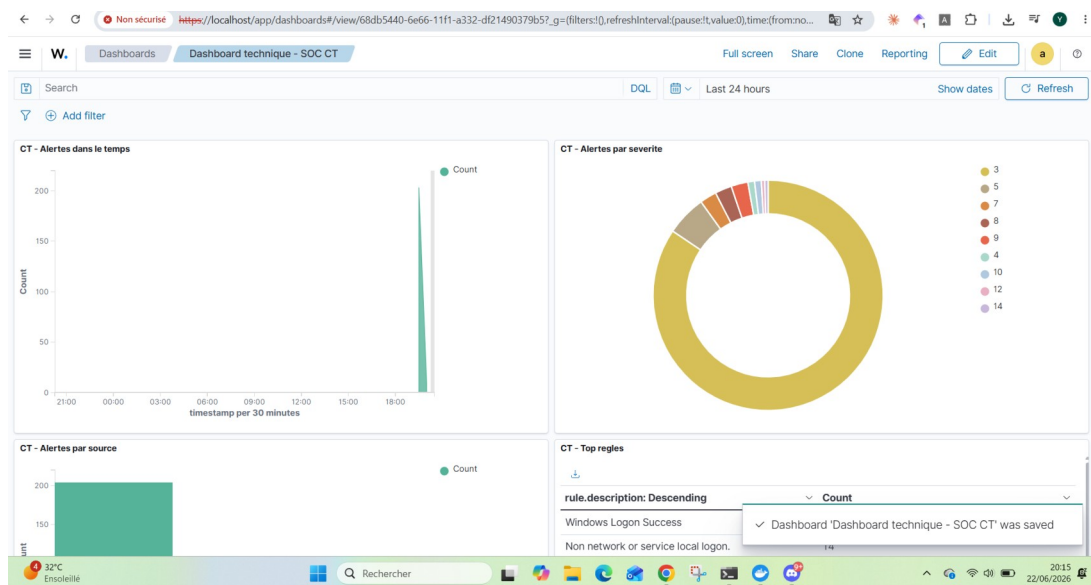
Mode dry-run, aucun envoi réseau.

```
[ad_files.log] 2026-06-23T09:31:44+02:00 daylight-ad-01 DAYLIGHT_AD event=privileged_group_change actor=svc-temp target=Domain
Admins action=add_member member=helpdesk demo risk=critical
[ad_files.log] 2026-06-23T09:33:18+02:00 daylight-files-01 DAYLIGHT_FILES event=patient_share_access user=stagiaire demo
path=\\daylight-files-01\patients\lyon\2026 result=denied risk=high
[ad_files.log] 2026-06-23T09:35:59+02:00 daylight-ad-01 DAYLIGHT_AD event=password_spray source=10.10.10.54 failures=18
window=5m risk=high
...
```

Source : tools/send_demo_logs_to_syslog.py --dry-run
 Preuve documentaire générée depuis les livrables du dossier ; elle ne prétend pas être une capture live d'un outil.

Figure - Rejeu de logs vers Wazuh : validation reproductible de l'ingestion et des règles attendues.

Les vues Wazuh ci-dessous complètent la démonstration : elles montrent que les alertes peuvent être suivies dans le temps, regroupées par sévérité, par source et par site. Cette séparation est importante pour un client multi-centres : le SOC conserve une vue globale, tout en gardant la possibilité d'isoler un centre Daylight précis.



5.6. Synthèse technique et conformité au cahier des charges

Le démonstrateur couvre les exigences essentielles du cahier des charges : collecte multi-source, SIEM open-source centralisé, règles personnalisables, dashboards, RBAC, playbooks, reporting et reproductibilité. Les limites sont assumées et documentées : il ne s'agit pas encore d'une production haute disponibilité, mais d'un socle prouvé et industrialisable.

Exigence	Statut	Commentaire
Collecte agents, syslog, logs applicatifs	Couvert	Endpoint, serveur Linux, Daylight et pfSense
SIEM open-source centralisé	Couvert	Wazuh Manager, Indexer, Dashboard
Dashboards lisibles et segmentés	Couvert	Dashboard technique et exécutif
Accès web par rôles	Couvert	Admin, analyste, supervision
Playbooks de réponse	Couvert	Scénarios documentés et exploitables
Scalabilité	Partiellement couverte	Modèle 30 sites décrit, industrialisation à renforcer en production
Automatisation API/CLI	Optionnel	Wazuh API et scripts de lab disponibles, extension SOAR possible

6. Conclusion

La principale limite du rendu est donc connue : le projet n'est pas une production haute disponibilité. Sa valeur est de donner une base claire, testée et extensible, que Cyber Trust pourrait transformer en pilote sur quelques centres Daylight.

Cyber Trust propose à Daylight un démonstrateur SOC cohérent, prouvé et défendable. L'intérêt du projet ne repose pas sur un seul outil, mais sur l'articulation entre architecture réseau, collecte, détection, qualification et réponse. La segmentation pfSense donne un cadre de sécurité lisible ; Wazuh apporte la centralisation, les règles et les dashboards ; les playbooks transforment les alertes en actions.

La solution reste volontairement adaptée au cadre pédagogique : certaines briques sont simulées, et l'architecture de production nécessiterait une haute disponibilité, une rétention dimensionnée, des sauvegardes, des tests de charge et une supervision continue des composants. Ces limites ne remettent pas en cause la valeur du démonstrateur ; elles définissent au contraire la trajectoire d'industrialisation.

La prochaine étape serait de formaliser un pilote sur quelques centres Daylight, puis de généraliser progressivement les templates de configuration, les règles, les dashboards et les procédures de réponse sur l'ensemble du réseau.

6.1. Guide d'utilisation synthétique

Pour rejouer la démonstration, l'équipe lance le lab Wazuh, vérifie l'état des sources, génère un scénario contrôlé puis valide l'apparition de l'alerte dans le dashboard. Le parcours attendu côté client est simple : ouvrir l'interface web, filtrer les événements par source ou règle, qualifier l'alerte et appliquer le playbook associé. Les preuves pfSense, Wazuh et les tableaux de flux servent de référentiel pour expliquer ce qui est autorisé, bloqué ou surveillé.

Action de recette	Résultat attendu	Preuve associée
Accéder au dashboard SOC	Interface web disponible avec vues adaptées au rôle.	Dashboard Wazuh, RBAC supervision/analyste/admin.
Vérifier les sources	Endpoint, serveur, application métier et pfSense produisent des événements.	Agents Wazuh, syslog firewall, logs Daylight.
Déclencher un scénario	Une alerte apparaît avec une règle identifiable et une sévérité exploitable.	SSH brute force, accès patient, blocage pfSense.
Qualifier l'alerte	L'analyste applique le playbook et documente la décision.	Playbooks et REX incidents.

Annexes

Annexe A : Liste des preuves intégrées au rapport

Preuve	Périmètre	Valeur démontrée
Schéma architecture globale	Yvan / architecture	Segmentation, pfSense, SOC, flux autorisés et bloqués
Règles LAN pfSense	Yvan / firewall	Politique de filtrage lisible et ordonnée
Syslog pfSense vers Wazuh	Yvan + Youssef	Collecte réseau vers le SIEM
Alertes pfSense Wazuh	Yvan + Youssef	Transformation des blocages réseau en alertes qualifiables
Dashboard technique Wazuh	Youssef / SIEM	Vue analyste par source, sévérité et règles
Dashboard exécutif Wazuh	Youssef + Kilyan	Vue client synthétique et lisible
Alerte SSH 5712	Youssef + Mahamadou	Détection force brute serveur
Alertes métier Daylight	Youssef + Mahamadou	Détection métier autour des données patients et privilèges
Playbooks de réponse	Mahamadou / exploitation SOC	Traitement opérationnel des scénarios prioritaires : SSH, patients, privilèges, USB et pfSense
Procédures d'exploitation lab	Mahamadou / maintien opérationnel	Vérification de démarrage, reprise de service et test bout en bout avant démonstration
REX incidents simulés	Mahamadou / amélioration continue	Limites observées, actions correctives et trajectoire d'industrialisation

Annexe B : Ports et flux principaux

Flux	Port	Usage
Agents Wazuh vers Manager	1514/TCP	Remontée des événements endpoint/serveur
Enrôlement agents	1515/TCP	Ajout contrôlé de nouveaux agents
pfSense vers Wazuh	514/UDP	Syslog firewall et événements réseau
Wazuh Dashboard	443/TCP	Interface web SOC
Wazuh API	55000/TCP	Administration et automatisation possible
Wazuh Indexer	9200/TCP	Recherche et indexation
Utilisateurs vers Daylight app	443/TCP	Accès métier HTTPS
Utilisateurs vers DNS autorisés	53 TCP/UDP	Résolution contrôlée

Annexe C : Recommandations d'industrialisation

Pour transformer le démonstrateur en service de production, Cyber Trust recommande de prioriser les chantiers suivants : segmentation VLAN complète, VPN d'administration, supervision de santé des composants, sauvegardes régulières, stratégie de rétention, chiffrement ou tunnelisation des flux syslog inter-sites, catalogue de règles élargi, tests de charge et processus de changement formalisé.

Chantier	Priorité	Justification
VLAN complets par zone	Haute	Rendre la segmentation réellement appliquée sur les sites
Haute disponibilité Wazuh/pfSense	Haute	Éviter un point de défaillance unique
Rétention et sauvegardes	Haute	Garantir l'analyse post-incident et la conformité
Catalogue de détection enrichi	Moyenne	Réduire les angles morts au fil des retours SOC
Automatisation onboarding	Moyenne	Accélérer le déploiement des 30 centres
Reporting client mensuel	Moyenne	Donner une vision claire de la posture sécurité

Annexe D : Schémas détaillés de la contribution architecture

Cette annexe complète la partie technique portée par Yvan FOCSA. Elle ne remplace pas la section principale du rapport groupe : elle sert de support de preuve et de lecture pour le client lorsque le jury souhaite vérifier la cohérence entre l'architecture, les règles pfSense, la journalisation et l'intégration Wazuh. Les fichiers sources restent disponibles dans le dépôt, dans le dossier Participants/Yvan_FOCSA.

Schéma pfSense, flux autorisés et flux bloqués

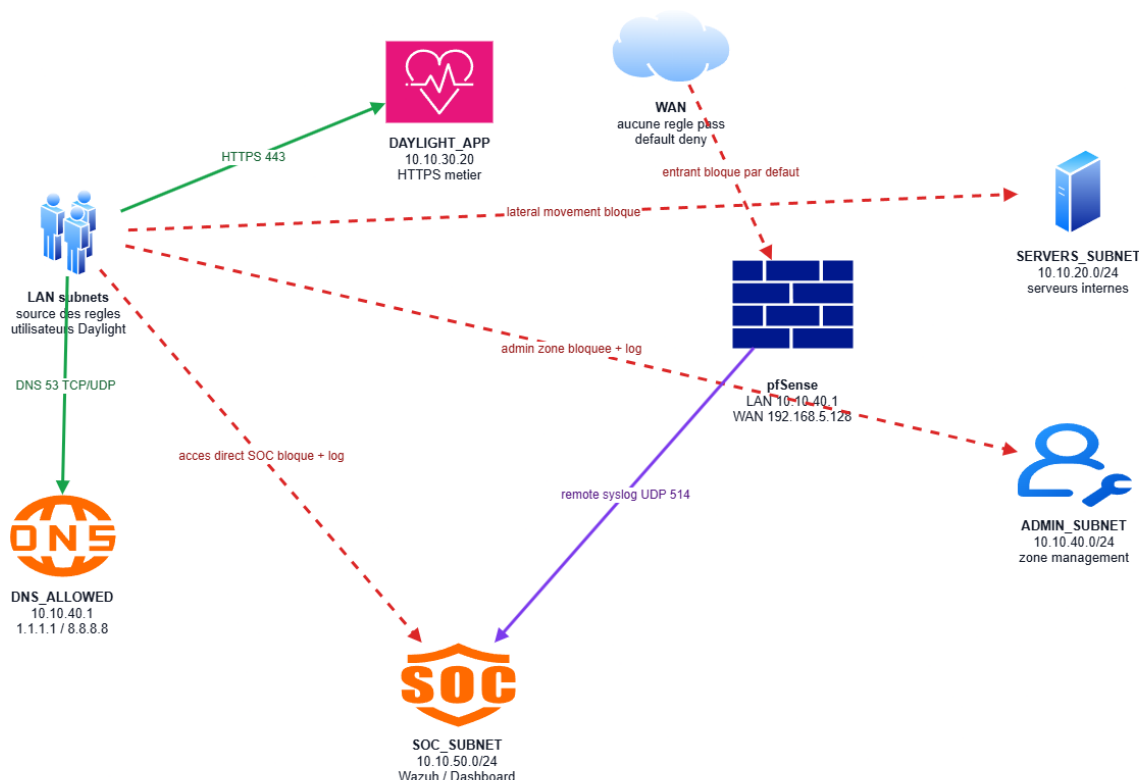


Figure complémentaire : pfSense comme point de contrôle des flux Daylight, avec les autorisations métier, les blocages de zones sensibles et la journalisation vers le SOC.

Ce schéma détaille la logique défendue dans la section pfSense du rapport : les utilisateurs disposent uniquement des flux nécessaires vers l'application métier et le DNS, tandis que les accès directs vers les zones serveurs, administration et SOC sont bloqués ou journalisés. Cette représentation permet au client de comprendre rapidement que la segmentation n'est pas seulement déclarative : elle est traduite en règles lisibles et vérifiables.

Schéma SOC Wazuh et chaîne de supervision

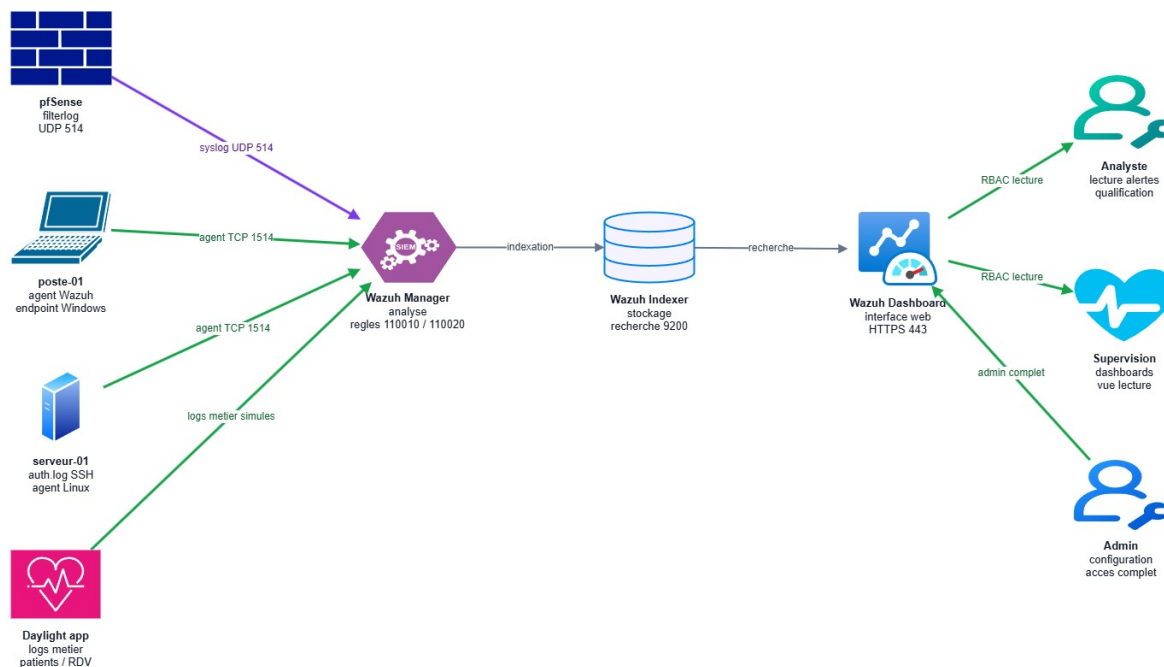


Figure complémentaire : chaîne SOC Wazuh, depuis les sources de logs jusqu'aux rôles analyste, supervision et administrateur.

Ce deuxième schéma relie la contribution réseau à la contribution SIEM. Il montre que pfSense n'est pas isolé : ses journaux sont envoyés vers Wazuh en syslog UDP 514, au même titre que les autres sources du démonstrateur. Les événements issus du firewall deviennent ensuite exploitables dans les vues Wazuh, avec des règles dédiées comme 110010 pour le trafic entrant bloqué et 110020 pour les tentatives de mouvement latéral vers l'administration.

Ressources associées dans le dépôt

La partie Yvan FOCSA du dépôt contient également la matrice Excel d'architecture, les captures pfSense, les exports de schémas et les fichiers de configuration. Ces éléments ne sont pas tous recopiés intégralement dans le corps du rapport pour conserver une lecture client fluide, mais ils sont disponibles comme preuves détaillées dans [Participants/Yvan FOCSA](#).